



Executive summary

AI AGENT + MCP SECURITY REVIEW

Scope: Selected source directory; paths below are relative | Invarune 0.11.0

Critical/high findings need prompt review

The scanner found 8 open critical/high patterns among 11 open findings. Confirm exposure and prioritize the actions below. Detector severity is not proof of exploitability or deployed risk.

11

OPEN FINDINGS

0

COVERAGE GAPS

3

FILES EXAMINED

Observed counts only. This is not an accuracy score or a security grade.

Deterministic layer: Selected static scope completed.

Optional model review: finding stage completed; control stage disabled. 2 model answers from 2 selected findings; 9 open findings outside the cap.

Immediate concerns

Priority / count	Observed location	Immediate concern and first action
P1 / AI001 1 open	agent.py:16	Dynamic Python code execution Trace the input to eval/exec and replace it with fixed operations; if generated execution is essential, isolate it before accepting untrusted input.
P1 / AI002 1 open	agent.py:9	Dynamic command executed through a shell Remove shell interpretation, select a fixed executable, and validate each argument and permitted option.
P1 / AI003 1 open	agent.py:10	Dynamic os shell command Replace os.system/os.popen with a fixed executable and validated argument list; trace all contributing values.
P1 / AI005 1 open	agent.py:12	Executable deserialization requires trusted inputs Establish who can produce and replace the input; migrate to a nonexecutable data format or restrict verified legacy artifacts to an isolated conversion path.
P1 / AI006 1 open	agent.py:11	TLS certificate verification disabled Enable certificate and hostname verification; install the intended CA for a private gateway and test rejection of an untrusted certificate.

Showing 5 of 11 open finding groups. Locations link to evidence; every proposed fix needs verification.

Record a review decision and rescan

Justified and disabled are human decisions, not passes. The full review forms and all evidence remain in this report.

Scan ID: c1ba5410b8710dd9fbcd73894eb74c7c7813cf78b6e3cecf80054db70682104c



Contents

Executive summary	1
Contents	2
Priorities and first actions	3
Observed findings and mitigating layers	4
Optional advisory review and evidence	17
Coverage gaps and required validation	19
Control checklist and evidence requirements	20
Scan configuration and scope	32
Deterministic checks and optional review	35
Coverage, misses and validation by area	36
Appendix / Deterministic rule inventory	40
Interactive review workspace	43



Priorities and first actions

Optional model review: finding stage completed; control stage disabled. 2 model answers from 2 selected findings; 9 open findings outside the cap.

Severity counts describe observed open patterns. They do not establish exploitability or an estimated probability of compromise.

Critical		0
High		8
Medium		2
Low		1
Info		0

Severity counts use the existing scanner rules; no model or reviewer score is added.

Fix guidance: 11/11 findings have deterministic fix plans and agent/MCP context. Model fix plans: 2/2 finding assessments; 0/0 answered checks. Proposals require verification.

Priority / count	Observed location	Immediate concern and first action
P1 / AI001 1 open	agent.py:16	Dynamic Python code execution Trace the input to eval/exec and replace it with fixed operations; if generated execution is essential, isolate it before accepting untrusted input.
P1 / AI002 1 open	agent.py:9	Dynamic command executed through a shell Remove shell interpretation, select a fixed executable, and validate each argument and permitted option.
P1 / AI003 1 open	agent.py:10	Dynamic os shell command Replace os.system/os.popen with a fixed executable and validated argument list; trace all contributing values.
P1 / AI005 1 open	agent.py:12	Executable deserialization requires trusted inputs Establish who can produce and replace the input; migrate to a nonexecutable data format or restrict verified legacy artifacts to an isolated conversion path.
P1 / AI006 1 open	agent.py:11	TLS certificate verification disabled Enable certificate and hostname verification; install the intended CA for a private gateway and test rejection of an untrusted certificate.
P1 / AI010 1 open	mcp.json:6	Credential-like literal in source or configuration Determine whether the value is real without reproducing it; revoke or rotate a real exposed credential and remove retained copies through the incident process.
P1 / AI029 1 open	mcp.json:10	Remote MCP URL uses plaintext HTTP Use HTTPS with verified certificates; if a separate protected transport is intentional, document and test every network hop and termination boundary.
P1 / AI031 1 open	mcp.json:7	Agent approval or sandbox safeguard explicitly bypassed Review the effective permission policy and restore bounded tools and runtime isolation; require independent approval for the specific sensitive effects.

Showing 8 of 11 open finding groups in priority order. The complete findings follow.

Review every detailed finding and gap below. Additional concerns can exist outside this bounded scan's supported syntax, files, budgets and execution context.



Observed findings and mitigating layers

AI001 / high / open

Dynamic Python code execution

agent.py:16

```
return eval(model_response)
```

Replace dynamic execution with an allowlisted operation dispatcher; use `ast.literal_eval` only for bounded literal parsing. Isolate unavoidable execution with no ambient credentials and strict resource limits.

[Record a decision, reason and reviewer for this finding](#)

[Additional defenses: Enforce action policy outside the model; Isolate tool execution](#)

Fix plan and agent/MCP relevance

Replace dynamic Python evaluation with a bounded operation interface.

Why this matters for agents/MCP: An agent can convert a prompt or MCP tool result into an `eval/exec` argument. If that value reaches this call, model influence becomes Python execution with the tool process identity.

Inspect the reported source location and its callers, change the implementation or effective configuration, then rebuild and rescan. The scan does not establish that this code is on an active agent or MCP request path.

Confirm applicability: Trace the expression from its producer to this exact call; a nonliteral expression alone does not establish external control or an active agent path.

Confirm applicability: Trusted fixed startup code and deliberately isolated code-execution services need different treatment; document which boundary applies.

1. Remove the interpreter boundary

Replace `eval/exec` with a dictionary of fixed callable operations and validate a small JSON argument schema before selecting a callable. Do not permit callers to name arbitrary modules, attributes or Python expressions.

Verify: Send unsupported operation names and extra arguments through the same tool entry point; verify rejection before any callable executes.

2. Choose a bounded data parser

For data, prefer JSON plus explicit type, length and nesting limits. Use `ast.literal_eval` only when Python literals are genuinely required, with independent input and resource bounds; it is not a general untrusted-input sandbox.

Verify: Exercise malformed, oversized and deeply nested values in an isolated test and confirm bounded failure without evaluating names or calls.

3. Isolate required generated execution

If code execution is the product feature, route it to a disposable worker with a separate identity, scoped workspace, no ambient credentials, bounded CPU/memory/time and denied-by-default egress.

Verify: Attempt a forbidden workspace read, network request and long-running task in a test worker; retain denials and verify cleanup.

Remaining validation: A permitted operation may still violate tenant or business policy; authorize target resources outside the model.

Remaining validation: Rescanning can confirm removal of a recognized expression, not sandbox strength or absence of alternate execution paths.

Related controls: EXEC-02

[REM-PY-AST / Python `ast.literal\_eval` security and resource limits](#)

[OWASP-AGENT-CS / AI Agent Security Cheat Sheet](#)

[JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems](#)

AI002 / high / open

Dynamic command executed through a shell

agent.py:9

```
subprocess.run(user_command, shell=True)
```

Pass an argument list with `shell=False`, allowlist executable names and options, and enforce working-directory and resource restrictions.

[Record a decision, reason and reviewer for this finding](#)

[Additional defenses: Enforce action policy outside the model; Isolate tool execution](#)

Fix plan and agent/MCP relevance

Remove shell parsing and constrain the actual executable and its arguments.



Why this matters for agents/MCP: An agent or MCP tool often translates model-selected operations into subprocess commands. Untrusted arguments embedded in a shell string can turn one permitted tool action into additional commands.

Inspect the reported source location and its callers, change the implementation or effective configuration, then rebuild and rescan. The scan does not establish that this code is on an active agent or MCP request path.

Confirm applicability: Determine whether each dynamic component can be influenced by user, retrieval, model or tool content.

Confirm applicability: `shell=False` is insufficient when the selected program is itself `sh`, `bash`, `cmd`, `PowerShell` or another interpreter receiving generated code.

1. Use a fixed process invocation

Replace `shell=True` and shell-specific helpers with `subprocess.run` using an argument list, `shell=False`, a fixed executable path and an explicit timeout. Replace pipelines with separate bounded calls or native library operations.

Verify: Submit spaces, quotes and shell metacharacters as data to a harmless test executable; assert the expected argument vector and that no additional process starts.

2. Validate argument meaning

Allowlist flags and resource identifiers, reject caller-selected executables, and use an end-of-options delimiter only where the chosen utility supports it. Do not treat `shlex.split` or shell quoting as authorization.

Verify: Test leading-dash filenames, unexpected flags and an interpreter executable; verify policy blocks them before process creation.

3. Constrain process authority

Set a permitted working directory and minimal environment, bound output and runtime, and apply a separate low-privilege execution identity where required. Review Windows batch-file behavior on the actual platform.

Verify: Run denial tests for forbidden files, inherited credentials and excessive output on each deployed operating system.

Remaining validation: Argument arrays prevent shell parsing but cannot prevent dangerous valid options or harmful allowed operations.

Remaining validation: Process timeouts do not by themselves establish descendant-process cleanup or OS isolation.

Related controls: EXEC-01

[REM-PY-SUBPROCESS / Python subprocess: security considerations](#)

[OWASP-AGENT-CS / AI Agent Security Cheat Sheet](#)

AI003 / high / open

Dynamic os shell command

```
agent.py:10
```

```
os.system(user_command)
```

Use subprocess with a fixed executable and argument list, `shell=False`, and explicit allowed options.

[Record a decision, reason and reviewer for this finding](#)

[Additional defenses: Enforce action policy outside the model; Isolate tool execution](#)

Fix plan and agent/MCP relevance

Replace `os.system/os.popen` with a fixed executable and validated argument list.

Why this matters for agents/MCP: An MCP command tool may interpolate planner output into `os.system` or `os.popen`. Those APIs introduce a shell boundary that can expand attacker-controlled syntax into the server account privileges.

Inspect the reported source location and its callers, change the implementation or effective configuration, then rebuild and rescan. The scan does not establish that this code is on an active agent or MCP request path.

Confirm applicability: Inspect the command construction and upstream validation at the reported call; this rule does not prove an attacker can supply the value.

Confirm applicability: If the operation is file copying, listing or parsing, a dedicated library API often removes the shell requirement entirely.

1. Remove os shell APIs

Replace the operation with a native library call or `subprocess.run([fixed_executable, validated_argument], shell=False, timeout=...)`. Split intentional pipelines into explicit stages with bounded output.

Verify: Use a harmless fixture containing shell metacharacters and assert it is processed as one argument or rejected, without a second command.

2. Restrict operations before execution

Bind the tool name to a fixed executable and authorized workspace; validate flags and resource ownership independently of the prompt and of shell escaping.

Verify: Call the server directly with an unauthorized path, extra option and different executable; verify rejection even without the agent planner.



3. Close inherited authority

Supply a minimal environment, avoid carrying gateway/cloud credentials into the child, and enforce cancellation plus output limits.

Verify: Inspect the test child environment and attempt an overlong operation; confirm sensitive variables are absent and the process is stopped.

Remaining validation: A correctly formed command can still modify the wrong tenant resource; policy enforcement and runtime identity remain necessary.

Related controls: EXEC-01

REM-PY-SUBPROCESS / Python subprocess: security considerations

MCP-TOOLS / MCP: Tools

AI005 / high / open

Executable deserialization requires trusted inputs

agent.py:12

```
return pickle.loads(serialized_data), data.text
```

Use a nonexecutable serialization format with schema validation. If compatibility requires pickle, accept only authenticated artifacts from a strictly controlled producer.

Record a decision, reason and reviewer for this finding

Additional defenses: Verify artifact identity before use; Separate artifact conversion from production

Fix plan and agent/MCP relevance

Replace executable object deserialization or tightly authenticate its producer.

Why this matters for agents/MCP: A cached agent state, plugin artifact or MCP-uploaded file may reach pickle-compatible loading. Deserialization can execute producer-selected code before downstream data validation.

Inspect the reported source location and its callers, change the implementation or effective configuration, then rebuild and rescan. The scan does not establish that this code is on an active agent or MCP request path.

Confirm applicability: Identify the producer and every write path to the artifact, including shared caches, object stores and task workspaces.

Confirm applicability: The finding identifies a dangerous loader; it does not show that its input is attacker controlled.

1. Migrate to data-only serialization

Replace pickle, dill, joblib or equivalent object loading with JSON or another nonexecutable format plus a versioned schema. Reconstruct only explicitly supported application types.

Verify: Roundtrip required benign state and reject unexpected type markers, fields and oversized collections without importing producer-selected code.

2. Control unavoidable legacy artifacts

If compatibility requires executable deserialization, authenticate the exact bytes against a producer/key or registry digest established independently of the artifact location. Restrict cache and artifact writers.

Verify: Alter one byte and change the producer identity in test artifacts; verify rejection before the deserializer is called.

3. Quarantine conversion

Convert legacy artifacts in a disposable credential-free worker with resource and network limits, then export validated data to the main service.

Verify: Verify conversion cannot read main-service secrets or contact forbidden destinations and that failed conversions publish no partial trusted state.

Remaining validation: A valid signature identifies a producer; it does not make a compromised or malicious producer safe.

Remaining validation: Schema validation after pickle loading is too late to prevent execution during loading.

Related controls: EXEC-06

TECH-PYTHON-SECURITY / Python Security Considerations

JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems

AI006 / high / open

TLS certificate verification disabled

agent.py:11

```
data = requests.get(remote_url, verify=False)
```

Enable certificate verification and install the correct CA bundle; use a trusted private CA for custom gateways.

Record a decision, reason and reviewer for this finding

Additional defenses: Require authenticated encrypted transport; Restrict outbound destinations independently



Fix plan and agent/MCP relevance

Restore certificate and hostname verification, including custom gateways.

Why this matters for agents/MCP: The affected connection can carry model credentials, prompts, MCP tool requests or retrieved evidence. Disabling TLS verification lets a reachable intermediary impersonate that peer and influence both data and agent decisions.

Inspect the reported source location and its callers, change the implementation or effective configuration, then rebuild and rescan. The scan does not establish that this code is on an active agent or MCP request path.

Confirm applicability: Confirm which client and effective session settings apply; the detected literal does not prove this connection is used in production.

Confirm applicability: A private gateway CA is a trust-distribution requirement, not a reason to disable peer verification.

1. Restore authenticated TLS

Remove `verify=False`, `CERT_NONE` and `hostname-check` bypasses. Use the client default trust store or supply an approved CA bundle through its supported verification setting.

Verify: Against a test endpoint, reject an untrusted certificate and wrong hostname while accepting the intended certificate chain.

2. Provision gateway trust explicitly

Distribute the private CA through the runtime trust configuration, verify the configured gateway hostname, and document CA rotation. Keep credentials out of URL query strings and diagnostics.

Verify: Exercise certificate renewal and CA rollover in a staging environment; confirm the client never retries with verification disabled.

3. Inspect effective runtime overrides

Check environment variables, shared HTTP sessions, proxies and image/deployment configuration for remaining bypasses on model and MCP clients.

Verify: Run the actual deployment client through the intended proxy/gateway and retain handshake results plus redacted configuration evidence.

Remaining validation: Valid TLS authenticates the endpoint name, not the endpoint operator trustworthiness or its data-retention practices.

Related controls: MCP-01

REM-REQUESTS-TLS / Requests: SSL certificate verification

MCP-SECURITY / MCP Security Best Practices

AI010 / high / open

Credential-like literal in source or configuration

mcp.json:6

[REDACTED: credential-related source evidence; inspect this location locally]

If real, revoke and rotate the credential, remove it from source and history, and load it from a secret manager or environment variable with least privilege.

Record a decision, reason and reviewer for this finding

Additional defenses: Investigate and contain confirmed secret exposure; Use managed credential injection and revocation; Limit credentials available to the workload

Fix plan and agent/MCP relevance

Classify the detected credential, rotate real exposure and remove embedded values.

Why this matters for agents/MCP: A hardcoded model, gateway or downstream-tool key can grant access outside the intended agent session and tenant. Repository or image readers may obtain the credential independently of the agent approval path.

Inspect the reported source location and its callers, change the implementation or effective configuration, then rebuild and rescan. The scan does not establish that this code is on an active agent or MCP request path.

Confirm applicability: Determine whether the value is a real credential, a nonsecret identifier or deliberate test data without copying the value into tickets or model prompts.

Confirm applicability: The detector does not validate the credential with its provider and does not establish prior misuse.

1. Revoke or rotate confirmed live credentials

Identify the credential owner and permissions using secret-safe metadata. Revoke or rotate real exposed credentials with a staged application update and review provider audit records.

Verify: Verify the old credential is rejected and the replacement has only required model/tool scopes; retain redacted rotation evidence.



2. Remove literals from delivery artifacts

Replace the literal with a secret-manager lookup or runtime injection. Remove it from tracked files, distributed image layers and relevant build artifacts; coordinate any history rewrite with repository owners.

Verify: Rescan the source and every retained image layer, and check logs/build artifacts for the old credential through a protected secret-scanning workflow.

3. Limit future credential reach

Use separate per-service or per-tenant credentials where supported and restrict which tool workers receive them. Exclude local secret files from version control and build contexts.

Verify: Run a tool that does not need the credential and verify it cannot read it; confirm clean builds do not embed injected build secrets.

Remaining validation: Deleting source text does not invalidate a copied credential; rotation and access review remain necessary.

Remaining validation: Environment injection can still expose secrets through process inheritance or diagnostics.

Related controls: AUTH-05, DATA-01

[CISA-SECURE-BY-DESIGN / Shifting the Balance of Cybersecurity Risk: Principles and Approaches for Secure by Design Software](#)

[MCP-SECURITY / MCP Security Best Practices](#)

AI029 / high / open

Remote MCP URL uses plaintext HTTP

mcp.json:10

"url": "http://mcp.example.invalid/mcp"

Use HTTPS with certificate verification for remote MCP endpoints. Reserve plaintext HTTP for explicitly controlled local development or a documented protected transport.

[Record a decision, reason and reviewer for this finding](#)

[Additional defenses: Require authenticated encrypted transport; Limit credentials available to the workload](#)

Fix plan and agent/MCP relevance

Use verified HTTPS for remote MCP endpoints and inspect every transport hop.

Why this matters for agents/MCP: Remote MCP requests can contain access tokens, task context and tool output. Plain HTTP exposes those bytes and allows modification by parties able to observe or influence the network path.

Inspect the reported source location and its callers, change the implementation or effective configuration, then rebuild and rescan. The scan does not establish that this code is on an active agent or MCP request path.

Confirm applicability: Confirm that the address is actually remote and identify TLS termination, tunnels and any plaintext backend hop.

Confirm applicability: Controlled loopback development and documented protected transport have different exposure; a URL alone cannot prove the effective network protections.

1. Configure an HTTPS endpoint

Replace the nonloopback HTTP MCP URL with the approved HTTPS service URL and require certificate/hostname verification. Provision a private CA when needed.

Verify: Use the actual MCP client to reject a wrong-host or untrusted certificate and accept the approved endpoint.

2. Check proxy-to-backend protection

Inspect all hops after TLS termination and restrict any plaintext backend segment to an explicitly controlled boundary, or use TLS/mTLS between components.

Verify: Verify the deployment path, listeners and policy prevent an unauthorized peer from observing or reaching the backend segment.

3. Remove insecure fallback and redirects

Ensure client retries and redirects cannot downgrade to HTTP or send credentials to another origin. Update environment/configuration overrides alongside the launch manifest.

Verify: Make the secure test endpoint fail or redirect to HTTP and confirm the client does not transmit an authenticated plaintext request.

Remaining validation: TLS does not validate tool results or protect secrets deliberately sent to an untrusted MCP server.

Related controls: MCP-01

[MCP-HTTP / MCP: Streamable HTTP transport](#)

[MCP-AUTH / MCP: Authorization](#)

[JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems](#)



AI031 / high / open

Agent approval or sandbox safeguard explicitly bypassed

mcp.json:7

```
"autoApprove": ["*"]
```

Use bounded tool permissions and an isolated runtime; require deliberate approval for destructive, external, financial, or credential-bearing actions.

[Record a decision, reason and reviewer for this finding](#)

[Additional defenses: Enforce action policy outside the model; Bind sensitive actions to explicit approval; Isolate tool execution](#)

Fix plan and agent/MCP relevance

Restore task-bound execution permissions and meaningful approval boundaries.

Why this matters for agents/MCP: Disabling agent approval or sandbox safeguards lets model-driven actions inherit the full process authority. Prompt injection or a mistaken plan can then modify files, send data or invoke credentials without the intended review boundary.

Inspect the reported source location and its callers, change the implementation or effective configuration, then rebuild and rescan. The scan does not establish that this code is on an active agent or MCP request path.

Confirm applicability: Confirm the exact agent/runtime setting and the environment it affects; dedicated controlled evaluation environments may intentionally bypass prompts.

Confirm applicability: Approval dialogs alone do not create OS isolation, and a sandbox alone does not establish user consent for external effects.

1. Replace unrestricted mode with explicit permissions

Remove bypass flags and configure the agent runtime permitted tools, workspace roots and network destinations for the task. Keep privileged administration in a separate identity/session.

Verify: Attempt a tool outside the task allowlist and a workspace/egress escape; verify the enforcement layer denies it without relying on model compliance.

2. Bind approvals to concrete actions

Require deliberate approval for relevant destructive, external, credential-bearing or financial effects, displaying target and material arguments. Expire approvals and recheck changed arguments.

Verify: Test a denied action, replayed approval and target substitution after approval; verify no unapproved side effect occurs.

3. Enforce isolation independently

Run tool workers with limited OS credentials, mounts, resource budgets and network rights. Propagate reduced authority to subagents and connectors.

Verify: Launch a delegated task and confirm it cannot acquire broader permissions, read host secrets or exceed the configured runtime budget.

Remaining validation: Users may approve misleading actions and allowed operations may be composed harmfully; adversarial workflow tests and audit trails remain needed.

Related controls: AGT-01, AGT-02, MCP-09, SUP-05

[OWASP-AGENT-CS / AI Agent Security Cheat Sheet](#)

[MCP-TOOLS / MCP: Tools](#)

AI018 / medium / open

MCP package runner resolves an unpinned artifact

mcp.json:4

```
"command": "npm",
```

Pin an exact audited package version and lock or verify transitive artifacts. Prefer preinstalled verified tools in a controlled environment.

[Record a decision, reason and reviewer for this finding](#)

[Additional defenses: Resolve and install reviewed dependency bytes; Verify artifact identity before use; Limit credentials available to the workload](#)

Fix plan and agent/MCP relevance

Pin MCP launch artifacts and make the effective installation reproducible.

Why this matters for agents/MCP: An MCP client often launches a package with its local user permissions and injected credentials. Unpinned npm/yarn resolution can replace the tool implementation between launches without a reviewed configuration change.

Inspect the reported source location and its callers, change the implementation or effective configuration, then rebuild and rescan. The scan does not establish that this code is on an active agent or MCP request path.

Confirm applicability: Inspect the actual package runner, registry and cache/lock behavior; a project lockfile may not govern an independent ephemeral runner.



Confirm applicability: An exact version reduces movement but does not prove package integrity or constrain all transitive dependencies.

1. Pin the selected package

For npm execution specify an exact package version, including scope where applicable; for uvx use an exact package version or explicit `--from package==version`. Keep the chosen package identity distinct from its executable name.

Verify: Start from a clean controlled cache and record the resolved package/version; verify the MCP launch command selects that exact artifact.

2. Verify the complete runtime artifact

Prefer a preinstalled tool built from a reviewed lockfile or verified artifact, with an approved registry and integrity data for dependencies. Audit additional `--with packages` and `executable-search paths`.

Verify: Compare fresh installations in controlled environments and investigate any dependency/artifact digest differences.

3. Limit launch credentials and updates

Run the server with only task-required credentials and workspace permissions. Propose version updates through review, provenance checks and regression tests rather than enabling automatic latest resolution.

Verify: Verify the launched process identity/environment and exercise a required tool after a reviewed update without expanding its permissions.

Remaining validation: Package cache isolation is not an operating-system sandbox; a pinned compromised package still executes with its granted authority.

Related controls: MCP-09, SUP-01

REM-UV-TOOLS / uv: tool versions and environments

REM-NPM-EXEC / npm exec: package selection and execution

MCP-SECURITY / MCP Security Best Practices

AI021 / medium / open

Container explicitly runs as root

Dockerfile:2

USER root

COPY . /app

Use a dedicated nonroot runtime user and minimal capabilities; verify the final build stage and deployment security context.

Record a decision, reason and reviewer for this finding

Additional defenses: Apply runtime isolation controls together; Separate risky tools from sensitive workloads

Fix plan and agent/MCP relevance

Use a dedicated nonroot runtime identity and verify effective permissions.

Why this matters for agents/MCP: An injected or overbroad agent/MCP tool action inherits the container process identity. Root can increase access to mounted data and the impact of an isolation failure, although container root is not automatically host root.

Inspect the reported source location and its callers, change the implementation or effective configuration, then rebuild and rescan. The scan does not establish that this code is on an active agent or MCP request path.

Confirm applicability: The finding concerns an explicit image/build default; deployment `runAsUser`, rootless runtimes and user namespaces may alter its effect.

Confirm applicability: Review the final selected build stage and actual running UID rather than assuming every build-stage root command runs in production.

1. Set the runtime user

Create a dedicated service account during build and select it with `USER` in the final runtime stage. In Kubernetes, configure `runAsNonRoot` and an appropriate numeric `runAsUser` where required.

Verify: Inspect the built image user and the running process UID under the actual deployment; test startup fails rather than silently switching to root.

2. Provision only required writable paths

Set ownership for explicit runtime/cache/workspace directories, avoid broad `chmod` permissions, and use a read-only root filesystem where compatible.

Verify: Run normal tool operations and verify they work only in approved writable directories; confirm system and other-tenant paths are denied.

3. Remove adjacent privilege paths

Drop unnecessary capabilities, disable privilege escalation and avoid host mounts/runtime sockets. Ensure an entrypoint does not restore privilege.

Verify: Inspect effective capabilities, mounts and deployment overrides and perform denied-access tests as the worker identity.

Remaining validation: Nonroot execution reduces authority but does not establish tenant isolation or eliminate kernel/runtime escapes.



Related controls: SUP-05

[REM-K8S-PODS / Kubernetes Pod Security Standards](#)

[REM-DOCKER-SECURITY / Docker Engine security and daemon access](#)

AI024 / low / open

Container image is not digest pinned

Dockerfile:1

FROM python:latest

Pin approved image digests, track provenance and SBOMs, and update through reviewed vulnerability-remediation workflows.

[Record a decision, reason and reviewer for this finding](#)

[Additional defenses: Verify artifact identity before use; Keep pinned artifacts maintained](#)

Fix plan and agent/MCP relevance

Pin the approved image content digest and maintain a reviewed update process.

Why this matters for agents/MCP: Agent/MCP deployments may execute a different tool stack when a mutable image tag moves. That changes the code holding credentials and enforcing tool policy without a matching application source change.

Inspect the reported source location and its callers, change the implementation or effective configuration, then rebuild and rescan. The scan does not establish that this code is on an active agent or MCP request path.

Confirm applicability: Inspect the image selected by the actual build/deployment and platform; tags may already be constrained by external admission policy.

Confirm applicability: Digest pinning controls content identity, not whether the pinned content is safe or current.

1. Record and pin the intended digest

Replace mutable base/deployment references with the approved registry image@sha256 digest, retaining a human-readable version where useful. Record the intended platform or multi-platform index.

Verify: Resolve the approved reference through the build/deployment system and verify the running image digest matches the recorded artifact/platform.

2. Review provenance and contents

Associate the digest with build provenance, an SBOM and a separate vulnerability scan; verify the publisher and build process before approving it.

Verify: Trace the selected digest to the expected build and verify the SBOM and vulnerability results apply to that exact artifact.

3. Update pins deliberately

Use automation to propose digest updates, rebuild and run agent/MCP regression and policy checks, then roll out the reviewed artifact.

Verify: Exercise rollback to a previously approved digest and confirm updates do not silently widen runtime permissions.

Remaining validation: A digest can preserve a vulnerable version indefinitely if updates are neglected; this scanner does not perform a CVE feed lookup.

Related controls: SUP-01, SUP-03

[REM-DOCKER-BUILD / Docker: pin base image versions](#)

[JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems](#)

AI001 / Enforce action policy outside the model

Proposed control; effectiveness has not been verified.

How it helps: Have an execution service allow only named operations, permitted argument values, and caller-owned target resources before invoking a tool.

Evidence to obtain: Exercise disallowed operations, additional arguments, cross-tenant identifiers, and direct calls that bypass the agent planner.

Remaining limit: Authorized operations can still be harmful when business constraints are incomplete; prompt instructions cannot enforce this boundary.

Related controls: AGT-01, AUTH-02, MCP-02

[MCP-TOOLS / MCP: Tools](#)

[OWASP-AGENT-CS / AI Agent Security Cheat Sheet](#)



AI001 / Isolate tool execution

Proposed control; effectiveness has not been verified.

How it helps: Run the risky tool in a separate, disposable identity with no host mounts, ambient credentials, or unnecessary outbound access.

Evidence to obtain: In a test environment, attempt reads outside the workspace, forbidden network connections, and resource exhaustion; retain policy and denial evidence.

Remaining limit: Isolation limits reachable assets; it does not make injected code trustworthy or rule out a runtime escape.

Related controls: EXEC-02, SUP-05, OPS-02

[JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems](#)

AI002 / Enforce action policy outside the model

Proposed control; effectiveness has not been verified.

How it helps: Have an execution service allow only named operations, permitted argument values, and caller-owned target resources before invoking a tool.

Evidence to obtain: Exercise disallowed operations, additional arguments, cross-tenant identifiers, and direct calls that bypass the agent planner.

Remaining limit: Authorized operations can still be harmful when business constraints are incomplete; prompt instructions cannot enforce this boundary.

Related controls: AGT-01, AUTH-02, MCP-02

[MCP-TOOLS / MCP: Tools](#)

[OWASP-AGENT-CS / AI Agent Security Cheat Sheet](#)

AI002 / Isolate tool execution

Proposed control; effectiveness has not been verified.

How it helps: Run the risky tool in a separate, disposable identity with no host mounts, ambient credentials, or unnecessary outbound access.

Evidence to obtain: In a test environment, attempt reads outside the workspace, forbidden network connections, and resource exhaustion; retain policy and denial evidence.

Remaining limit: Isolation limits reachable assets; it does not make injected code trustworthy or rule out a runtime escape.

Related controls: EXEC-02, SUP-05, OPS-02

[JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems](#)

AI003 / Enforce action policy outside the model

Proposed control; effectiveness has not been verified.

How it helps: Have an execution service allow only named operations, permitted argument values, and caller-owned target resources before invoking a tool.

Evidence to obtain: Exercise disallowed operations, additional arguments, cross-tenant identifiers, and direct calls that bypass the agent planner.

Remaining limit: Authorized operations can still be harmful when business constraints are incomplete; prompt instructions cannot enforce this boundary.

Related controls: AGT-01, AUTH-02, MCP-02

[MCP-TOOLS / MCP: Tools](#)

[OWASP-AGENT-CS / AI Agent Security Cheat Sheet](#)

AI003 / Isolate tool execution

Proposed control; effectiveness has not been verified.

How it helps: Run the risky tool in a separate, disposable identity with no host mounts, ambient credentials, or unnecessary outbound access.

Evidence to obtain: In a test environment, attempt reads outside the workspace, forbidden network connections, and resource exhaustion; retain policy and denial evidence.

Remaining limit: Isolation limits reachable assets; it does not make injected code trustworthy or rule out a runtime escape.

Related controls: EXEC-02, SUP-05, OPS-02

[JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems](#)



AI005 / Verify artifact identity before use

Proposed control; effectiveness has not been verified.

How it helps: Require reviewed artifact provenance plus a digest or signature checked against an independently trusted identity or manifest.

Evidence to obtain: Substitute bytes, producer identity, or verification metadata in a controlled test and confirm the consumer rejects the artifact.

Remaining limit: Authenticity establishes the producer and bytes; an approved producer can still ship vulnerable or malicious content.

Related controls: SUP-03, DATA-04

[OPENSSE-MODEL-SIGNING / Launch of Model Signing v1.0](#)

[SLSA-12 / Supply-chain Levels for Software Artifacts specification](#)

AI005 / Separate artifact conversion from production

Proposed control; effectiveness has not been verified.

How it helps: Perform necessary conversion of legacy serialized artifacts in a disposable environment without production data or credentials.

Evidence to obtain: Demonstrate that a conversion job cannot reach production services and only approved output formats are promoted.

Remaining limit: Conversion output still needs integrity, format, and downstream behavior review; isolation is not proof of benign content.

Related controls: EXEC-06, SUP-06

[JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems](#)

[TECH-PYTORCH-SERIAL / PyTorch Serialization semantics](#)

AI006 / Require authenticated encrypted transport

Proposed control; effectiveness has not been verified.

How it helps: Use verified TLS on every relevant network hop, with an appropriate public or private CA and validated service hostname.

Evidence to obtain: Present an untrusted, expired, or wrong-host certificate and verify rejection; inspect backend traffic after TLS termination.

Remaining limit: TLS does not protect data from an authorized endpoint, compromised gateway, or plaintext segments beyond termination.

Related controls: MCP-01, AUTH-05

[MCP-AUTH / MCP: Authorization](#)

[MCP-AUTH-SEC / MCP: Authorization Security Considerations](#)

AI006 / Restrict outbound destinations independently

Proposed control; effectiveness has not been verified.

How it helps: Enforce an outbound policy outside the application that permits only required destinations and services; include IPv6 and proxy paths.

Evidence to obtain: From the deployed identity, test direct IP, DNS, redirect, metadata-service, and proxy-mediated attempts to prohibited destinations.

Remaining limit: Allowed destinations may themselves accept leaked data; destination rules do not replace content and action authorization.

Related controls: EXEC-05, AGT-07, SUP-05

[JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems](#)

[MCP-SECURITY / MCP Security Best Practices](#)

AI010 / Investigate and contain confirmed secret exposure

Proposed control; effectiveness has not been verified.

How it helps: For a real exposed credential, identify reachable systems, revoke or rotate it, and review access records for misuse.

Evidence to obtain: Confirm the old credential no longer works and record the exposure window, affected copies, and follow-up owner.

Remaining limit: Successful rotation stops future use of that credential but cannot reverse access or data loss that already occurred.

Related controls: AUTH-05, OPS-06

[CISA-JCDC / JCDC AI Cybersecurity Collaboration Playbook and Fact Sheet \(release notice\)](#)

[NIST-SSDF / Secure Software Development Framework \(SSDF\) Version 1.1](#)



AI010 / Use managed credential injection and revocation

Proposed control; effectiveness has not been verified.

How it helps: Load secrets at runtime through an approved store or workload identity; keep them out of source, artifacts, and model context.

Evidence to obtain: Test rotation and revocation without disclosing values; inspect build layers and launch metadata for retained copies.

Remaining limit: Deleting a file or hiding a later image layer does not revoke a credential or erase copies already distributed.

Related controls: AUTH-05, DATA-01, DATA-06

[JOINT-AGENTIC / Careful adoption of agentic AI services](#)

[MCP-AUTH / MCP: Authorization](#)

AI010 / Limit credentials available to the workload

Proposed control; effectiveness has not been verified.

How it helps: Give this component a distinct identity and only the downstream scopes and lifetime needed for its approved operations.

Evidence to obtain: Use its runtime identity to attempt forbidden service operations, then revoke it and confirm subsequent access fails.

Remaining limit: A compromised component can still use its allowed permissions until credentials expire or revocation takes effect.

Related controls: AUTH-05, AUTH-09

[JOINT-AGENTIC / Careful adoption of agentic AI services](#)

AI029 / Require authenticated encrypted transport

Proposed control; effectiveness has not been verified.

How it helps: Use verified TLS on every relevant network hop, with an appropriate public or private CA and validated service hostname.

Evidence to obtain: Present an untrusted, expired, or wrong-host certificate and verify rejection; inspect backend traffic after TLS termination.

Remaining limit: TLS does not protect data from an authorized endpoint, compromised gateway, or plaintext segments beyond termination.

Related controls: MCP-01, AUTH-05

[MCP-AUTH / MCP: Authorization](#)

[MCP-AUTH-SEC / MCP: Authorization Security Considerations](#)

AI029 / Limit credentials available to the workload

Proposed control; effectiveness has not been verified.

How it helps: Give this component a distinct identity and only the downstream scopes and lifetime needed for its approved operations.

Evidence to obtain: Use its runtime identity to attempt forbidden service operations, then revoke it and confirm subsequent access fails.

Remaining limit: A compromised component can still use its allowed permissions until credentials expire or revocation takes effect.

Related controls: AUTH-05, AUTH-09

[JOINT-AGENTIC / Careful adoption of agentic AI services](#)

AI031 / Enforce action policy outside the model

Proposed control; effectiveness has not been verified.

How it helps: Have an execution service allow only named operations, permitted argument values, and caller-owned target resources before invoking a tool.

Evidence to obtain: Exercise disallowed operations, additional arguments, cross-tenant identifiers, and direct calls that bypass the agent planner.

Remaining limit: Authorized operations can still be harmful when business constraints are incomplete; prompt instructions cannot enforce this boundary.

Related controls: AGT-01, AUTH-02, MCP-02

[MCP-TOOLS / MCP: Tools](#)

[OWASP-AGENT-CS / AI Agent Security Cheat Sheet](#)

AI031 / Bind sensitive actions to explicit approval

Proposed control; effectiveness has not been verified.

How it helps: Require an independent approval for the exact actor, tool, normalized arguments, target, and expiry before irreversible effects occur.

Evidence to obtain: Change arguments after approval, replay the approval, and call after expiry; each attempt must be denied before a side effect.

Remaining limit: Approval cannot compensate for misleading previews, excessive approver authority, or actions that happen before the check.

Related controls: AGT-02, OPS-04

[OWASP-AGENT-CS / AI Agent Security Cheat Sheet](#)



AI031 / Isolate tool execution

Proposed control; effectiveness has not been verified.

How it helps: Run the risky tool in a separate, disposable identity with no host mounts, ambient credentials, or unnecessary outbound access.

Evidence to obtain: In a test environment, attempt reads outside the workspace, forbidden network connections, and resource exhaustion; retain policy and denial evidence.

Remaining limit: Isolation limits reachable assets; it does not make injected code trustworthy or rule out a runtime escape.

Related controls: EXEC-02, SUP-05, OPS-02

[JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems](#)

AI018 / Resolve and install reviewed dependency bytes

Proposed control; effectiveness has not been verified.

How it helps: Use a committed lock or approved artifact manifest, enforce it during installation, and retain the resolved dependency inventory.

Evidence to obtain: Build in a clean environment and compare resolved bytes; modify a lock or artifact and verify the release gate rejects it.

Remaining limit: An exact version or digest can still identify a vulnerable artifact; mutable transitive dependencies must also be constrained.

Related controls: SUP-01, SUP-03

[NIST-SSDF / Secure Software Development Framework \(SSDF\) Version 1.1](#)

[OPENSSEF-BASELINE-202608 / Open Source Project Security Baseline](#)

AI018 / Verify artifact identity before use

Proposed control; effectiveness has not been verified.

How it helps: Require reviewed artifact provenance plus a digest or signature checked against an independently trusted identity or manifest.

Evidence to obtain: Substitute bytes, producer identity, or verification metadata in a controlled test and confirm the consumer rejects the artifact.

Remaining limit: Authenticity establishes the producer and bytes; an approved producer can still ship vulnerable or malicious content.

Related controls: SUP-03, DATA-04

[OPENSSEF-MODEL-SIGNING / Launch of Model Signing v1.0](#)

[SLSA-12 / Supply-chain Levels for Software Artifacts specification](#)

AI018 / Limit credentials available to the workload

Proposed control; effectiveness has not been verified.

How it helps: Give this component a distinct identity and only the downstream scopes and lifetime needed for its approved operations.

Evidence to obtain: Use its runtime identity to attempt forbidden service operations, then revoke it and confirm subsequent access fails.

Remaining limit: A compromised component can still use its allowed permissions until credentials expire or revocation takes effect.

Related controls: AUTH-05, AUTH-09

[JOINT-AGENTIC / Careful adoption of agentic AI services](#)

AI021 / Apply runtime isolation controls together

Proposed control; effectiveness has not been verified.

How it helps: Use a dedicated nonroot identity, minimal capabilities, no privilege escalation, and an enforced syscall and mandatory-access policy where supported.

Evidence to obtain: Inspect the effective workload and attempt privileged operations, prohibited syscalls, and access to protected host resources.

Remaining limit: Nonroot alone is insufficient; writable mounts, added capabilities, host namespaces, and kernel flaws can weaken isolation.

Related controls: SUP-05, TEST-05

[CIS-CONTROLS-81 / CIS Critical Security Controls v8.1](#)

[JOINT-DEPLOY / Deploying AI Systems Securely: Best Practices for Deploying Secure and Resilient AI Systems](#)



AI021 / Separate risky tools from sensitive workloads

Proposed control; effectiveness has not been verified.

How it helps: Place tools needing exceptional privileges in a separate environment with narrow interfaces and no unrelated tenant data.

Evidence to obtain: Test cross-workload network and filesystem access and confirm the privileged component cannot impersonate the requesting agent.

Remaining limit: Shared kernels or administrative infrastructure may retain common failure paths; a container is not automatically a strong hostile-code boundary.

Related controls: SUP-05, TEST-04, GOV-02

[CSA-CCM / Cloud Controls Matrix and CAIQ v4.1](#)

[JOINT-AGENTIC / Careful adoption of agentic AI services](#)

AI024 / Verify artifact identity before use

Proposed control; effectiveness has not been verified.

How it helps: Require reviewed artifact provenance plus a digest or signature checked against an independently trusted identity or manifest.

Evidence to obtain: Substitute bytes, producer identity, or verification metadata in a controlled test and confirm the consumer rejects the artifact.

Remaining limit: Authenticity establishes the producer and bytes; an approved producer can still ship vulnerable or malicious content.

Related controls: SUP-03, DATA-04

[OPENSSE-MODEL-SIGNING / Launch of Model Signing v1.0](#)

[SLSA-12 / Supply-chain Levels for Software Artifacts specification](#)

AI024 / Keep pinned artifacts maintained

Proposed control; effectiveness has not been verified.

How it helps: Review known-vulnerability and maintenance evidence for the actual resolved artifacts and apply updates through a repeatable release process.

Evidence to obtain: Demonstrate a dependency update, relevant regression checks, and deployment or rollback of the resulting approved artifact.

Remaining limit: This source/image scan does not provide a current CVE verdict, and a vulnerability database cannot identify every unknown flaw.

Related controls: SUP-02, SUP-04, OPS-05

[NIST-SSDF / Secure Software Development Framework \(SSDF\) Version 1.1](#)

[OPENSSE-SCORECARD / OpenSSF Scorecard](#)



Optional advisory review and evidence

Model interpretations are advisory. They do not dismiss static findings, prove control effectiveness or change deterministic evidence. A verified quotation proves its presence in the supplied excerpt, not the correctness of the interpretation.

Omissions, evidence collection limits, errors and budgets are recorded in the optional-review summary above. Proposed verification steps have not been executed by this scanner.

Finding review: 979d192981c1785a2394fe19

Verdict: likely_true_positive

Reason: `run_tool` passes `user_command` directly to `subprocess.run` with `shell=True`, allowing shell syntax to execute. The snippet establishes the dangerous sink, but not whether an untrusted caller can reach it or what isolation applies. Trace callers and command construction to verify the trust boundary.

Model-proposed fix guidance (unverified)

Agent/MCP relevance: If agent-generated commands or MCP arguments reach `user_command`, external content could influence shell execution with the tool process's privileges. MCP exposure is not established.

When this applies: Applies when `user_command` can be influenced by an agent or another caller lacking authority to execute arbitrary shell commands.

1. Replace command strings with structured operation arguments mapped to fixed executable paths; call `subprocess.run(argv, shell=False)`, validating each operation's permitted options and operands.
2. If arbitrary shell execution is an intended capability, document that contract and enforce authorization and an isolated execution environment with restricted credentials, filesystem access, network access, and execution time.

Verify: Trace `run_tool` callers to identify who controls `user_command` and which authorization or isolation controls apply.

Verify: In an isolated test environment, verify that shell metacharacters are rejected or passed literally and that supported operations retain their intended behavior.

Finding review: 0fa7e450cd583d78646ef397

Verdict: likely_true_positive

Reason: `os.system(user_command)` directly sends the function argument to a shell. Untrusted influence would permit shell command injection, although caller provenance and runtime privileges are unknown. The preceding `subprocess.run` also executes the same command, so verify whether this second invocation is intentional.

Model-proposed fix guidance (unverified)

Agent/MCP relevance: An agent or MCP caller controlling `user_command` could cross from tool input into process execution. The supplied context does not establish actual agent or MCP reachability.

When this applies: Applies if callers are intended to request bounded operations rather than unrestricted shell execution.

1. Replace `os.system` with `subprocess.run` using a fixed executable, validated argument list, and `shell=False`.
2. Determine whether both execution calls are required; if duplication is accidental, consolidate into one validated `subprocess.run` call while preserving required output and failure behavior.

Verify: Review callers and the tool contract to establish permitted operations and whether duplicate execution is expected.

Verify: Use an isolated test with a harmless observable operation to check invocation count, argument handling, output, and failure behavior.

Additional model concern - unverified

`pickle.loads(serialized_data)` can execute code during deserialization. It is unknown whether `serialized_data` is attacker-controlled or restricted to trusted producers; trace its origin and integrity protections.

Model-proposed fix guidance (unverified)

Agent/MCP relevance: If agent or MCP input reaches `serialized_data`, deserialization could execute code with server privileges. Input provenance is unverified.

When this applies: Applies when `serialized_data` crosses a trust boundary from an untrusted or compromiseable producer.

1. For untrusted input, replace `pickle.loads` with `json.loads` and explicit schema validation; define a compatible data representation for any currently required Python-specific types.
2. If trusted pickle support is required, establish and enforce the trusted-producer boundary before retaining it; do not treat post-deserialization validation as protection.

Verify: Trace `serialized_data` through all callers and storage or transport paths.

Verify: Verify that the replacement accepts required legitimate payloads and rejects malformed or unsupported data without invoking `pickle.loads`.



Additional model concern - unverified

`requests.get(remote_url, verify=False)` explicitly disables TLS certificate verification. Interception risk depends on HTTPS use and network conditions; establish URL schemes and the intended certificate trust configuration.

Model-proposed fix guidance (unverified)

Agent/MCP relevance: Intercepted responses could feed altered data or instructions into an agent if `data.text` is consumed downstream; that downstream use is unverified.

When this applies: Applies when `remote_url` uses HTTPS and authenticated server identity is required.

1. Remove `verify=False` to use Requests' default certificate verification, or set `verify` to an approved CA bundle path for private certificates.
2. If the tool requires authenticated encrypted transport, validate that `remote_url` and followed redirects use HTTPS.

Verify: Verify that a server with a trusted certificate succeeds and servers with an untrusted certificate or hostname mismatch fail.

Verify: Check private-CA deployments against the configured CA bundle to preserve intended connectivity.

Additional model concern - unverified

`requests.get(remote_url, ...)` may permit server-side request forgery if an untrusted caller controls `remote_url` and the process can reach sensitive destinations. URL validation, redirect handling, and network restrictions are not shown.

Model-proposed fix guidance (unverified)

Agent/MCP relevance: Caller-controlled URLs could make an agent tool or MCP server access resources unavailable to the caller directly. Exposure and effective network access are unknown.

When this applies: Applies if `remote_url` is influenced by untrusted input and destinations are intended to be restricted.

1. Define permitted schemes, hosts, and ports; parse `remote_url` with `urllib.parse.urlsplit` and enforce that policy before `requests.get`.
2. Set `allow_redirects=False` or revalidate each redirect destination, and enforce destination restrictions through an egress proxy or network policy covering resolved addresses.

Verify: Trace URL provenance and inspect existing validation and egress controls before changing behavior.

Verify: In a controlled environment, check permitted destinations and denial of disallowed destinations, redirects, IPv6 addresses, and DNS changes.



Coverage gaps and required validation

No operational gap was recorded within the selected scope. Unsupported runtime properties still require their own checks.



Control checklist and evidence requirements

GOV-01 / Inventory every agent, MCP server, tool, and model

Scanner status: manual_review_required | validation: manual

1. Record owner, deployment, model/version, MCP transport/version, exposed tools, data classes, and external endpoints.

Record review for GOV-01:1

2. Reconcile approved inventory with deployed configurations; investigate unregistered agents and servers.

Record review for GOV-01:2

<https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-ai-rmf-10>

GOV-02 / Model trust boundaries and attack paths

Scanner status: manual_review_required | validation: manual

1. Diagram user, model, memory, tool, server, gateway, and downstream service boundaries with their credentials.

Record review for GOV-02:1

2. Identify who controls each input and the highest-impact action reachable if that input is malicious.

Record review for GOV-02:2

<https://github.com/mitre-atlas/atlas-data>

<https://csrc.nist.gov/pubs/ai/100/2/e2025/final>

GOV-03 / Define authorized use and accountable owners

Scanner status: manual_review_required | validation: manual

1. Assign an owner to each autonomous action and document permitted purposes, forbidden outcomes, and escalation routes.

Record review for GOV-03:1

2. Record impact, reversibility, approval requirements, and accepted residual risk before production use.

Record review for GOV-03:2

<https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-ai-rmf-10>

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/careful-adoption-o...>

GOV-04 / Maintain evidence and risk exceptions

Scanner status: manual_review_required | validation: manual

1. Give each control an owner, evidence link, validation date, result, and next review date.

Record review for GOV-04:1

2. Time-limit exceptions and require a compensating control; distinguish untested behavior from demonstrated failure.

Record review for GOV-04:2

<https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf>

<https://csrc.nist.gov/pubs/sp/800/218/final>

GOV-05 / Reassess changes in autonomy and integrations

Scanner status: manual_review_required | validation: manual

1. Review security impact when adding a model, tool, server, data source, skill, or broader permission.

Record review for GOV-05:1

2. Require deployment evidence for the complete configured system; a model-only score is insufficient.

Record review for GOV-05:2

<https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development>



GOV-06 / Assign shared security responsibilities across AI providers

Scanner status: manual_review_required | validation: manual

1. For each model, gateway, orchestrator, MCP service, and cloud provider, document which party implements each applicable safeguard and which customer configuration it depends on.

Record review for GOV-06:1

2. Obtain current supplier evidence for inherited safeguards, identify unowned gaps, and record reassessment triggers in the service review.

Record review for GOV-06:2

<https://cloudsecurityalliance.org/artifacts/ai-controls-matrix-v1-1>

<https://cloudsecurityalliance.org/artifacts/cloud-controls-matrix-v4-1>

AUTH-01 / Authenticate protected operations on every request

Scanner status: no_pattern_detected | validation: hybrid

1. Trace authentication to every protected HTTP entry point, including tool calls, subscriptions, and retries.

Record review for AUTH-01:1

2. Verify missing, expired, revoked, or malformed credentials cannot invoke a protected operation.

Record review for AUTH-01:2

<https://modelcontextprotocol.io/specification/2026-07-28/basic/authorization>

AUTH-02 / Authorize the exact action and target

Scanner status: no_pattern_detected | validation: hybrid

1. Check user/agent identity, tenant, tool, target object, and requested operation immediately before execution.

Record review for AUTH-02:1

2. Deny by default; test read-only callers against write tools and object identifiers owned by another user.

Record review for AUTH-02:2

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/careful-adoption-o...>

<https://modelcontextprotocol.io/specification/2026-07-28/server/tools>

AUTH-03 / Validate access-token cryptography and claims

Scanner status: no_pattern_detected | validation: hybrid

1. Verify signature with trusted keys, allowed algorithms, expected issuer/audience, expiry, and required scopes.

Record review for AUTH-03:1

2. Reject unsigned tokens and tokens minted for another service; decoding a JWT alone is not validation.

Record review for AUTH-03:2

<https://modelcontextprotocol.io/specification/2026-07-28/basic/authorization/security-considerations>

AUTH-04 / Prevent token passthrough and confused deputy use

Scanner status: no_pattern_detected | validation: hybrid

1. Use audience-bound MCP credentials and separately authorized downstream credentials; never forward arbitrary caller tokens.

Record review for AUTH-04:1

2. Ensure a proxy cannot use its broader service identity to perform an action the caller cannot authorize.

Record review for AUTH-04:2

<https://modelcontextprotocol.io/specification/2026-07-28/basic/authorization>

https://modelcontextprotocol.io/docs/2026-07-28/tutorials/security/security_best_practices



AUTH-05 / Constrain credential lifetime and exposure

Scanner status: findings_detected | validation: hybrid

1. Use short-lived scoped credentials where supported, protect refresh tokens, and validate rotation and revocation.

Record review for AUTH-05:1

2. Avoid tokens in query strings, model context, source, child-process arguments, and diagnostic output.

Record review for AUTH-05:2

<https://modelcontextprotocol.io/specification/2026-07-28/basic/authorization/security-considerations>

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/deploying-ai-syste...>

AUTH-06 / Bind OAuth flows and validate redirects

Scanner status: no_pattern_detected | validation: hybrid

1. Test PKCE support and S256, exact registered redirects, transaction binding, and authorization-response issuer validation.

Record review for AUTH-06:1

2. Reject replayed codes, mismatched issuers, unsafe redirect schemes, and unsolicited callback transactions.

Record review for AUTH-06:2

<https://modelcontextprotocol.io/specification/2026-07-28/basic/authorization/security-considerations>

<https://modelcontextprotocol.io/specification/2026-07-28/basic/authorization>

AUTH-07 / Secure OAuth discovery and registration

Scanner status: review_required | validation: hybrid

1. Validate discovered metadata and client metadata URLs before fetching; constrain schemes, destinations, redirects, and response sizes.

Record review for AUTH-07:1

2. Document trust policy for client registration and prevent discovery from reaching internal metadata or privileged network services.

Record review for AUTH-07:2

https://modelcontextprotocol.io/docs/2026-07-28/tutorials/security/security_best_practices

AUTH-08 / Bind delegation to identity, scope, and expiry

Scanner status: review_required | validation: hybrid

1. Carry authenticated initiator and delegation identity through multi-agent calls instead of trusting identity fields in text.

Record review for AUTH-08:1

2. Prevent agents from granting themselves privileges; limit delegation scope, depth, lifetime, and downstream audiences.

Record review for AUTH-08:2

https://cheatsheetseries.owasp.org/cheatsheets/AI_Agent_Security_Cheat_Sheet.html

AUTH-09 / Manage agent identity enrollment and retirement

Scanner status: runtime_validation_required | validation: dynamic

1. Enroll agents under an accountable sponsor and approved workload identity; verify identity claims before issuing credentials or granting discovery and execution access.

Record review for AUTH-09:1

2. Test retirement, sponsor departure, redeployment, and identity compromise; remove stale credentials, cached grants, registrations, and downstream access.

Record review for AUTH-09:2

<https://cloudsecurityalliance.org/artifacts/agent-ai-identity-and-access-management-a-new-approach>

<https://www.nccoe.nist.gov/publications/other/accelerating-adoption-software-and-ai-agent-identity-an...>

MCP-01 / Validate transport exposure and origin

Scanner status: findings_detected | validation: hybrid

1. For HTTP, reject invalid Origin values and verify local deployments bind only to intended interfaces.

Record review for MCP-01:1

2. Use TLS for remote protected endpoints; test DNS rebinding and proxy/header behavior in deployment.

Record review for MCP-01:2

<https://modelcontextprotocol.io/specification/2026-07-28/basic/transports/streamable-http>



MCP-02 / Validate tool arguments and results

Scanner status: review_required | validation: hybrid

1. Apply schemas and semantic bounds before executing every tool; reject unknown properties where appropriate.

Record review for MCP-02:1

2. Bound sizes and nesting; validate declared structured output and render errors without leaking secrets.

Record review for MCP-02:2

<https://modelcontextprotocol.io/specification/2026-07-28/server/tools>

MCP-03 / Treat descriptions and annotations as untrusted

Scanner status: review_required | validation: hybrid

1. Inspect descriptions, schemas, resources, icons, and results for instructions that cross tool or user boundaries.

Record review for MCP-03:1

2. Never let readOnlyHint, destructiveHint, or other server claims replace independent authorization and approval policy.

Record review for MCP-03:2

<https://modelcontextprotocol.io/specification/2026-07-28/server/tools>

https://cheatsheetseries.owasp.org/cheatsheets/MCP_Security_Cheat_Sheet.html

MCP-04 / Detect tool substitution and metadata changes

Scanner status: review_required | validation: hybrid

1. Bind tool approval to verified server identity and the reviewed tool definition or version.

Record review for MCP-04:1

2. Revalidate changes after reconnect/list updates; disambiguate collisions across servers without trusting display names.

Record review for MCP-04:2

<https://owasp.org/projects/mcp-top-10>

MCP-05 / Protect state handles and legacy sessions

Scanner status: no_pattern_detected | validation: dynamic

1. Authorize every state handle against its owner and tenant; enforce expiry, unpredictability, and replay boundaries.

Record review for MCP-05:1

2. For older sessionful protocol versions, test session hijacking and cross-user resumption; a session ID is not authentication.

Record review for MCP-05:2

<https://modelcontextprotocol.io/specification/2026-07-28/server/tools>

https://modelcontextprotocol.io/docs/2026-07-28/tutorials/security/security_best_practices

MCP-06 / Constrain sampling and returned model context

Scanner status: runtime_validation_required | validation: dynamic

1. Apply host policy and user control to sampling requests, context sharing, model selection, and associated tool access.

Record review for MCP-06:1

2. Test whether an untrusted server can induce disclosure from unrelated conversations or recursively consume model budget.

Record review for MCP-06:2

<https://modelcontextprotocol.io/specification/2026-07-28/client/sampling>

MCP-07 / Secure elicitation and URL interactions

Scanner status: review_required | validation: hybrid

1. Keep sensitive credential collection out of form-mode elicitation; validate and visibly identify URL destinations.

Record review for MCP-07:1

2. Test cancellation, phishing URLs, unsolicited interactions, and replayed completion state against the selected protocol version.

Record review for MCP-07:2

<https://modelcontextprotocol.io/specification/2026-07-28/client/elicitation>



MCP-08 / Enforce filesystem isolation independently of roots

Scanner status: no_pattern_detected | validation: hybrid

1. Treat declared roots as scoped information, not an operating-system sandbox or complete authorization mechanism.

Record review for MCP-08:1

2. Enforce allowed paths at file access and test traversal, symlinks, alternate encodings, and writes outside the workspace.

Record review for MCP-08:2

<https://modelcontextprotocol.io/specification/2026-07-28/client/roots>

MCP-09 / Constrain local server launch and inherited environment

Scanner status: findings_detected | validation: hybrid

1. Approve executable and package identity before starting a stdio server; use argument arrays and a minimal environment.

Record review for MCP-09:1

2. Restrict proxy process-spawn APIs and child filesystem/network permissions; separate stdout protocol traffic from logs.

Record review for MCP-09:2

https://modelcontextprotocol.io/docs/2026-07-28/tutorials/security/security_best_practices

https://cheatsheetseries.owasp.org/cheatsheets/MCP_Security_Cheat_Sheet.html

MCP-10 / Apply version-aware metadata, caching, and cancellation

Scanner status: runtime_validation_required | validation: dynamic

1. Record supported revisions and test their capability, metadata, header consistency, stream, and cancellation rules.

Record review for MCP-10:1

2. Prevent caches and request continuations from crossing authorization contexts; do not apply legacy handshake assumptions universally.

Record review for MCP-10:2

<https://modelcontextprotocol.io/specification/2026-07-28/basic/transports>

<https://modelcontextprotocol.io/specification/2026-07-28/basic/transports/streamable-http>

AGT-01 / Enforce action policy outside the model

Scanner status: findings_detected | validation: hybrid

1. Place allow/deny decisions at the execution boundary using trusted policy inputs and constrained tool capabilities.

Record review for AGT-01:1

2. Show that an injected instruction cannot disable policy, choose privileged credentials, or bypass approval.

Record review for AGT-01:2

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/agentic-ai-harnesses>

AGT-02 / Bind approval to the action executed

Scanner status: findings_detected | validation: dynamic

1. Present actual recipient, target, arguments, data disclosure, and consequences for high-impact approval.

Record review for AGT-02:1

2. Invalidate approval if arguments or target change; test races, delayed retries, and approval reuse.

Record review for AGT-02:2

https://cheatsheetseries.owasp.org/cheatsheets/AI_Agent_Security_Cheat_Sheet.html

AGT-03 / Separate untrusted content from authoritative instructions

Scanner status: no_pattern_detected | validation: hybrid

1. Track origin and trust level for web pages, documents, messages, OCR, tool results, and repository instructions.

Record review for AGT-03:1

2. Test direct and indirect goal hijacking; formatting delimiters and prompt warnings alone are not access controls.

Record review for AGT-03:2

<https://genai.owasp.org/resource/owasp-genai-llm-top-10-2026/>



AGT-04 / Protect retrieval and persistent memory

Scanner status: review_required | validation: hybrid

1. Enforce document and memory ACLs at retrieval and update time, including vector search metadata filters.

Record review for AGT-04:1

2. Test poisoned memory persistence, cross-tenant retrieval, provenance loss, deletion, and stale privileged context.

Record review for AGT-04:2

<https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/>

AGT-05 / Keep objectives and authority bounded across agents

Scanner status: runtime_validation_required | validation: dynamic

1. Constrain delegated tasks and verify messages against authenticated senders, expected schemas, and allowed transitions.

Record review for AGT-05:1

2. Test impersonation, conflicting instructions, cascading failure, and privilege growth across handoffs.

Record review for AGT-05:2

<https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/>

AGT-06 / Protect agent configuration and skills

Scanner status: review_required | validation: hybrid

1. Inventory skill files, prompts, hooks, memory seed files, MCP configuration, and other executable workflow inputs.

Record review for AGT-06:1

2. Require review for changes that add commands, access, or persistence; external repository text cannot become trusted policy.

Record review for AGT-06:2

<https://github.com/mitre-atlas/atlas-data>

<https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development>

AGT-07 / Prevent sensitive context leaving through legitimate tools

Scanner status: runtime_validation_required | validation: dynamic

1. Apply destination and data policies to URLs, searches, tickets, messages, uploads, and telemetry generated by agents.

Record review for AGT-07:1

2. Use canary data to test encoded leakage and combinations of otherwise permitted tools.

Record review for AGT-07:2

https://cheatsheetseries.owasp.org/cheatsheets/MCP_Security_Cheat_Sheet.html

EXEC-01 / Prevent shell and command injection

Scanner status: findings_detected | validation: hybrid

1. Find shell execution and constructed command strings; use fixed executables, argument arrays, and allowed argument values.

Record review for EXEC-01:1

2. Test untrusted tool inputs containing shell syntax, option injection, command substitution, and hostile filenames.

Record review for EXEC-01:2

<https://owasp.org/projects/mcp-top-10>

<https://genai.owasp.org/llmrisk/llm052025-improper-output-handling/>

EXEC-02 / Constrain generated-code execution

Scanner status: findings_detected | validation: hybrid

1. Locate eval, exec, dynamic imports, templates, notebooks, and interpreter tools accepting model or user content.

Record review for EXEC-02:1

2. Run required code execution in a disposable restricted environment with explicit filesystem, network, CPU, and time limits.

Record review for EXEC-02:2

https://cheatsheetseries.owasp.org/cheatsheets/AI_Agent_Security_Cheat_Sheet.html



EXEC-03 / Parameterize database and query operations

Scanner status: no_pattern_detected | validation: hybrid

1. Use bound query parameters and allowed query shapes; inspect SQL, NoSQL, graph, and search-language construction.

Record review for EXEC-03:1

2. Separate read/write database identities and test whether generated queries can escape permitted objects or operations.

Record review for EXEC-03:2

<https://genai.owasp.org/llmrisk/llm052025-improper-output-handling/>

EXEC-04 / Constrain file and archive access

Scanner status: no_pattern_detected | validation: hybrid

1. Resolve and enforce allowed paths at access time; constrain uploads, downloads, extraction, temporary files, and permissions.

Record review for EXEC-04:1

2. Test symlink races, archive traversal, absolute paths, overwrite attempts, and secret-directory reads.

Record review for EXEC-04:2

<https://modelcontextprotocol.io/specification/2026-07-28/client/roots>

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/deploying-ai-syste...>

EXEC-05 / Prevent SSRF and unsafe network destinations

Scanner status: no_pattern_detected | validation: hybrid

1. Restrict destinations and schemes at connection time; revalidate DNS resolution and each redirect.

Record review for EXEC-05:1

2. Test loopback, private/link-local IPv4 and IPv6, cloud metadata, alternate encodings, and redirect-to-private cases.

Record review for EXEC-05:2

https://modelcontextprotocol.io/docs/2026-07-28/tutorials/security/security_best_practices

EXEC-06 / Reject unsafe parsing and deserialization

Scanner status: findings_detected | validation: hybrid

1. Inspect pickle, unsafe YAML, object deserialization, XML entity expansion, and unconstrained recursive parsers.

Record review for EXEC-06:1

2. Use data-only formats with byte, nesting, and type limits; test malformed input and expansion attacks.

Record review for EXEC-06:2

<https://csrc.nist.gov/pubs/sp/800/218/final>

EXEC-07 / Render model and tool output safely

Scanner status: no_pattern_detected | validation: hybrid

1. Use context-specific escaping for HTML/Markdown, avoid unsafe DOM sinks, and validate links and embedded media.

Record review for EXEC-07:1

2. Test active SVG/HTML, malicious URLs, terminal escapes, and spreadsheet formulas in exported reports.

Record review for EXEC-07:2

<https://genai.owasp.org/llmrisk/llm052025-improper-output-handling/>

DATA-01 / Detect and remove embedded credentials

Scanner status: findings_detected | validation: static

1. Inspect code, examples, configuration, notebooks, test fixtures, and generated artifacts for secret-like values.

Record review for DATA-01:1

2. Verify actual exposures with the owner, rotate real credentials, and remove them from reachable history and artifacts.

Record review for DATA-01:2

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/deploying-ai-syste...>



DATA-02 / Minimize data sent to models and gateways

Scanner status: manual_review_required | validation: manual

1. Map which prompts, tool outputs, memory, and code leave the environment and identify the receiving provider/gateway.

Record review for DATA-02:1

2. Document allowed data classes, processing location, retention, and training use; redact before transmission where required.

Record review for DATA-02:2

<https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf>

DATA-03 / Protect logs, traces, and error responses

Scanner status: no_pattern_detected | validation: hybrid

1. Redact secrets and sensitive payloads before logs, traces, exception strings, and dashboards persist them.

Record review for DATA-03:1

2. Test the failure paths and provider errors as well as success paths; restrict access and export destinations.

Record review for DATA-03:2

<https://owasp.org/projects/mcp-top-10>

DATA-04 / Track provenance and integrity of AI data

Scanner status: manual_review_required | validation: manual

1. Record source, owner, version, transformation history, and integrity evidence for datasets, retrieval corpora, and memory seeds.

Record review for DATA-04:1

2. Quarantine unexpected changes and test how poisoned or stale data is detected, removed, and replaced.

Record review for DATA-04:2

<https://www.nsa.gov/Press-Room/Press-Releases-Statements/Press-Release-View/Article/4192332/nsas-aisc...>

DATA-05 / Enforce retention and deletion across copies

Scanner status: runtime_validation_required | validation: dynamic

1. Apply expiry and deletion to prompts, embeddings, caches, memory, tool artifacts, backups, and provider-held data.

Record review for DATA-05:1

2. Verify deleting a source record removes or invalidates dependent retrieval content and access grants.

Record review for DATA-05:2

<https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf>

DATA-06 / Protect stored data and keys

Scanner status: review_required | validation: hybrid

1. Check transport verification, storage access controls, encryption settings, key separation, and backup permissions.

Record review for DATA-06:1

2. Validate key rotation and denied access using a principal outside the authorized tenant or operational role.

Record review for DATA-06:2

<https://www.nsa.gov/Press-Room/Press-Releases-Statements/Press-Release-View/Article/4192332/nsas-aisc...>

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/deploying-ai-syste...>

SUP-01 / Pin and inventory executable dependencies

Scanner status: findings_detected | validation: static

1. Review lockfiles and exact versions or immutable digests for packages, images, MCP servers, models, and plugins.

Record review for SUP-01:1

2. Flag runtime installs, floating tags, remote scripts, and dependency sources outside approved registries.

Record review for SUP-01:2

<https://csrc.nist.gov/pubs/sp/800/218/final>



SUP-02 / Check vulnerability and maintenance exposure

Scanner status: manual_review_required | validation: manual

1. Run appropriate package/container advisory tools against resolved dependencies and save database date and tool version.

Record review for SUP-02:1

2. Triage reachability, fix availability, support status, and transitive dependencies; source pattern scans do not establish CVE coverage.

Record review for SUP-02:2

<https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development>

SUP-03 / Verify artifact identity and provenance

Scanner status: findings_detected | validation: manual

1. Verify publisher identity, hashes/signatures, build provenance, and intended origin before enabling artifacts.

Record review for SUP-03:1

2. Review model loading and serialization behavior; an integrity hash cannot make an untrusted publisher safe.

Record review for SUP-03:2

<https://www.nsa.gov/Press-Room/Press-Releases-Statements/Press-Release-View/Article/4192332/nsas-aisc...>

<https://csrc.nist.gov/pubs/sp/800/218/final>

SUP-04 / Protect build, release, and configuration changes

Scanner status: no_pattern_detected | validation: hybrid

1. Restrict CI credentials and workflow permissions; review actions, build scripts, and release provenance.

Record review for SUP-04:1

2. Prevent untrusted contributions from executing with deployment secrets or changing approved agent policies.

Record review for SUP-04:2

<https://csrc.nist.gov/pubs/sp/800/218/final>

SUP-05 / Harden runtime isolation and deployment defaults

Scanner status: findings_detected | validation: hybrid

1. Review root/privileged containers, host mounts, Docker sockets, unrestricted egress, debug mode, and public management endpoints.

Record review for SUP-05:1

2. Separate agent execution from control-plane credentials and audit storage; test isolation in the deployed environment.

Record review for SUP-05:2

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/deploying-ai-syste...>

SUP-06 / Separate and protect model development environments

Scanner status: runtime_validation_required | validation: dynamic

1. When training or fine-tuning, isolate development, evaluation, and production identities, data access, registries, and release permissions.

Record review for SUP-06:1

2. Protect datasets, weights, adapters, and configuration separately; monitor modifications and demonstrate that an untrusted training job cannot replace an approved production artifact.

Record review for SUP-06:2

<https://csrc.nist.gov/pubs/sp/800/218/a/final>

OPS-01 / Produce attributable audit events

Scanner status: review_required | validation: hybrid

1. Record initiating identity, delegated identity, tool/server/version, approved arguments, decision, outcome, and correlation identifiers.

Record review for OPS-01:1

2. Protect log integrity and clock consistency; ensure agents cannot erase their own action history.

Record review for OPS-01:2

<https://owasp.org/projects/mcp-top-10>



OPS-02 / Bound work, spending, and concurrency

Scanner status: review_required | validation: hybrid

1. Set server-enforced limits for iterations, tokens, tool calls, recursion, parallelism, bytes, cost, and elapsed time.

Record review for OPS-02:1

2. Exercise stuck loops and amplification paths; verify limits apply across retries and child agents.

Record review for OPS-02:2

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/agent-ai-harnesses>

OPS-03 / Make cancellation and shutdown effective

Scanner status: runtime_validation_required | validation: dynamic

1. Provide a tested stop mechanism that revokes work, credentials, queued actions, and child tasks.

Record review for OPS-03:1

2. Measure stop latency and verify cancelled or disconnected requests cannot later commit prohibited side effects.

Record review for OPS-03:2

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/careful-adoption-o...>

OPS-04 / Fail safely and prevent duplicate side effects

Scanner status: runtime_validation_required | validation: dynamic

1. Deny or escalate when policy, identity, or approval checks fail; prevent fallback paths from widening privilege.

Record review for OPS-04:1

2. Test outages, partial failures, timeouts, retries, idempotency, and recovery of transactions with external effects.

Record review for OPS-04:2

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/agent-ai-harnesses>

OPS-05 / Monitor behavior and support rollback

Scanner status: runtime_validation_required | validation: dynamic

1. Alert on unusual tool use, new destinations, scope growth, repeated denials, cost spikes, and unexpected state changes.

Record review for OPS-05:1

2. Validate alerts with seeded events and test rollback of models, prompts, tools, policies, and poisoned memory.

Record review for OPS-05:2

<https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development>

OPS-06 / Practice incident response and disclosure

Scanner status: manual_review_required | validation: manual

1. Maintain procedures to isolate agents, revoke credentials, preserve evidence, notify owners, and recover trusted state.

Record review for OPS-06:1

2. Exercise an AI-specific incident and define approved vulnerability/intelligence-sharing channels without exposing sensitive evidence.

Record review for OPS-06:2

<https://www.cisa.gov/news-events/alerts/2025/01/14/cisa-releases-jcdc-ai-cybersecurity-collaboration-...>

TEST-01 / Measure prompt-injection security and useful task completion

Scanner status: runtime_validation_required | validation: dynamic

1. Run paired benign and adversarial workflows with representative tools and attacker-controlled external content.

Record review for TEST-01:1

2. Record attacker success, authorized task success, blocked benign actions, and the observed unauthorized side effect.

Record review for TEST-01:2

<https://github.com/ethz-spylab/agentdojo>

<https://github.com/uiuc-kang-lab/InjecAgent>



TEST-02 / Test adaptively and repeat scenarios

Scanner status: runtime_validation_required | validation: dynamic

1. Vary payload wording, placement, modality, attacker knowledge, and attempts; rerun after changing defenses.

Record review for TEST-02:1

2. Report per-scenario outcomes, sample counts, attack budget, uncertainty, and model/harness versions instead of only an average.

Record review for TEST-02:2

<https://www.nist.gov/news-events/news/2025/01/technical-blog-strengthening-ai-agent-hijacking-evaluat...>

TEST-03 / Exercise MCP authentication and protocol abuse

Scanner status: runtime_validation_required | validation: dynamic

1. In an isolated test environment, exercise invalid tokens, wrong audiences, origin abuse, malicious servers, and protocol fuzzing.

Record review for TEST-03:1

2. Adapt scenarios to the deployed MCP revision and transports; preserve request/response evidence with secrets removed.

Record review for TEST-03:2

<https://github.com/AIS2Lab/MCPSecBench>

<https://modelcontextprotocol.io/specification/2026-07-28/basic/authorization>

TEST-04 / Verify cross-tenant and cross-agent isolation

Scanner status: runtime_validation_required | validation: dynamic

1. Create two principals and attempt cross-access to objects, memory, caches, handles, subscriptions, and execution results.

Record review for TEST-04:1

2. Repeat after reconnect, delegation, failed authentication, concurrent requests, and privilege revocation.

Record review for TEST-04:2

<https://github.com/agiresearch/ASB>

TEST-05 / Test approval, policy, and sandbox bypass

Scanner status: runtime_validation_required | validation: dynamic

1. Use explicit forbidden-action canaries to verify enforcement survives hostile content, tool substitution, and delayed execution.

Record review for TEST-05:1

2. Confirm paths through retries, fallback models, alternate tools, and child agents enforce the same boundary.

Record review for TEST-05:2

https://cheatsheetseries.owasp.org/cheatsheets/AI_Agent_Security_Cheat_Sheet.html

TEST-06 / Verify conventional application security

Scanner status: runtime_validation_required | validation: dynamic

1. Run language-aware SAST, dependency review, secret scanning, and authorized integration tests for exposed services.

Record review for TEST-06:1

2. Exercise reachable injection, XSS, SSRF, path traversal, deserialization, and access-control risks with safe fixtures.

Record review for TEST-06:2

<https://csrc.nist.gov/pubs/sp/800/218/final>

<https://genai.owasp.org/llmrisk/llm052025-improper-output-handling/>

TEST-07 / Validate resource exhaustion and observability

Scanner status: runtime_validation_required | validation: dynamic

1. Simulate oversized messages, slow peers, streaming floods, repeated errors, runaway agents, and unavailable dependencies.

Record review for TEST-07:1

2. Verify quotas, shutdown, telemetry, and alerts work together without leaking payloads or losing attribution.

Record review for TEST-07:2

<https://www.cyber.gov.au/business-government/secure-design/artificial-intelligence/agent-ai-harnesses>



TEST-08 / Evaluate the optional security judge itself

Scanner status: runtime_validation_required | validation: dynamic

1. Treat repository text and model verdicts as untrusted; test prompt injection, fabricated locations, invalid JSON, and timeouts.

Record review for TEST-08:1

2. Compare against labeled cases, retain deterministic results, document model variability, and never equate a judge approval with control validation.

Record review for TEST-08:2

<https://www.nist.gov/news-events/news/2025/01/technical-blog-strengthening-ai-agent-hijacking-evaluat...>

<https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf>

TEST-09 / Evaluate model-layer attacks for hosted or customized models

Scanner status: runtime_validation_required | validation: dynamic

1. Where applicable, assess suspicious triggers, model extraction, and disclosure of private training examples under an explicit attacker access and query budget.

Record review for TEST-09:1

2. Retest acquired or retrained models and adapters before release; document measured failures, model identity, coverage limits, and accepted residual risk.

Record review for TEST-09:2

<https://cloudsecurityalliance.org/blog/2025/02/06/agent-ai-threat-modeling-framework-maestro>

<https://csrc.nist.gov/pubs/sp/800/218/a/final>



Scan configuration and scope

Source scope and limits

Setting	Configured value
Default excluded directories	.cache, .git, .hg, .mypy_cache, .next, .pytest_cache, .svn, .tox, .venv, __pycache__, build, coverage, dist, node_modules, vendor, venv
Exclude	None
Explicit exclusion identity scope	Existing selected files and directories, including case aliases and file hardlinks; inputs must remain stable during the scan. Device/inode identities are not persisted in reports.
Explicit exclusion matching	resolved_paths_and_snapshot_filesystem_identities
Generated outputs and judge config excluded	Yes
Max entries	100000
Max file bytes	1000000
Max files	20000
Max total bytes	50000000



Invocation and optional-review budgets

Setting	Configured value
Optional review / Analyst limits / Batch size	6
Optional review / Analyst limits / Max bytes	2000000
Optional review / Analyst limits / Max calls	12
Optional review / Analyst limits / Max chars	120000
Optional review / Analyst limits / Max files	200
Optional review / Analyst limits / Max seconds	180
Optional review / Cli login	never
Optional review / Cli timeout seconds	180.0
Optional review / Effective transport / Max request bytes	524288
Optional review / Effective transport / Max response bytes	1048576
Optional review / Effective transport / Model	gpt-6-astra
Optional review / Effective transport / Provider	codex_cli
Optional review / Effective transport / Timeout seconds	180.0
Optional review / Effective transport / Token optimizer	headroom
Optional review / Enabled	Yes
Optional review / Findings limit	2
Optional review / Include finding source	Yes
Optional review / Mode	findings
Optional review / Provider	codex_cli
Optional review / Transport replay	Endpoints, credentials, headers, executable paths and identity stores are not embedded for automatic replay.
Reporting / Failure threshold	high
Reporting / Formats	html, markdown, json, sarif, pdf
Review inputs / Baseline	No
Review inputs / Review config	No



Setting	Configured value
Review inputs / Review report	No
Schema version	1.0

Image limits

Not present for this scan.

Source and image evidence are static. Image metadata, retained layers and packaged files do not reveal every runtime override or compiled program behavior.

Scanner provenance

Identity	Recorded value
Display name	Invarune by NimeshBuild
Implementation sha256	993d77b77bac8f0f4758ce931da596ce03eb31a36a4fec4302efb2da601ffb80
Name	agent-mcp-security-scan
Python version	3.12.14
Version	0.11.0



Deterministic checks and optional review

42 static source/configuration patterns

Deterministic checks inspect bounded Python syntax and local value flow, JavaScript/TypeScript lexical structure, structured JSON, configuration settings, selected secret patterns and image metadata. Repeated stable input produces repeatable evidence; it does not guarantee zero false positives or negatives.

Optional security analyst

If enabled, a model reviews selected findings and acceptance checks using bounded supplied evidence. Strict IDs, citations, response validation and tool restrictions constrain the protocol. Partial budgets, omitted answers and unavailable source/runtime evidence remain visible. Advice does not independently prove safety or erase static findings.

Review layer	Actual outcome / coverage
Finding review	completed; 2 selected; 9 outside cap
Control review	Disabled; 0/0 active controls answered
Unanswered acceptance checks	0/0 requested checks
Control requests	0/0 configured calls
Finding-stage error	None recorded
Control-stage errors	None

What can be missed

Cross-module/interprocedural flow, reflection, dynamic loaders, complex language syntax, templates before rendering, unsupported languages, compiled image behavior, runtime authentication/authorization, tenant isolation, egress policy, dependency CVEs and adaptive prompt injection require additional validation. A source declaration or proposed mitigation is not deployment evidence.

Human/runtime review workflow



1. Review evidence and the immediate concern. 2. Record a decision, reason, reviewer, date and evidence reference. 3. Validate runtime or human-dependent controls in the applicable environment. 4. Save and import the edited PDF or equivalent JSON. 5. Resolve rejected/stale edits, then rescan. Gaps remain operationally incomplete; blank decisions retain existing scanner semantics.



Coverage, misses and validation by area

Controls with rule mapping		26
Controls without rule mapping		40

Catalog mapping counts are not passed controls or percent secure.

Mapping counts describe available checks, not percent secure, detection accuracy or validated control effectiveness.

Execution and data flow

Deterministic: Python AST checks with bounded local aliases/values; JavaScript/TypeScript tokens and balanced calls identify selected eval, shell, deserialization, SQL and template patterns.

Optional analyst: A model can explain a retrieved call path, question whether input is trusted and identify contextual concerns the pattern rules do not encode.

Can miss or misclassify: Cross-file flows, dynamic imports, wrappers, reflection, generated code, unsupported languages and runtime values can hide a risk. A dangerous API can also be intentional and correctly constrained.

Validate elsewhere: Exercise actual entry points with authorized negative tests; verify input provenance, execution privileges and sandbox boundaries.

MCP identity, authorization and tools

Deterministic: Selected configuration/code signals flag insecure transport, explicit authentication bypass, token passthrough, broad tool grants and unpinned server launch packages.

Optional analyst: A model can review supplied authorization logic, tool descriptions and trust-boundary evidence for missing assumptions or inconsistent checks.

Can miss or misclassify: Configuration may differ from deployment. External gateways, identity providers, token audience checks and tenant boundaries may be absent from retrieved evidence.

Validate elsewhere: Test expired/wrong-audience tokens, cross-tenant access, per-tool authorization, consent binding and the deployed MCP transport.

Prompt injection, retrieval and memory

Deterministic: Selected patterns identify external content placed in privileged model messages and explicit approval/sandbox bypass. This is not an attack simulation.

Optional analyst: A model can reason about untrusted-content handling, persistent memory, tool-output influence and missing approval boundaries in the supplied excerpts.

Can miss or misclassify: Adaptive attacks, multi-turn interactions and tool chains depend on runtime behavior. Retrieval can omit the relevant code; a model can overlook an attack or be influenced by hostile evidence.

Validate elsewhere: Run isolated adversarial agent/MCP evaluations with attack-success and legitimate-task measurements, plus human review of consequential actions.

Secrets and data handling

Deterministic: Selected literal credentials, plausible private-key material, credential-bearing URLs, logging patterns and browser credential exposure are flagged and redacted best-effort.

Optional analyst: A model can identify sensitive data flows and retention concerns when the supplied evidence explains their context.

Can miss or misclassify: Encoded, split or runtime-fetched credentials can be missed; labels/test values can resemble secrets. Neither layer establishes whether a credential is live or redaction is complete.

Validate elsewhere: Verify secret stores, credential rotation, logging/retention policy, egress destinations and actual data-access permissions.

Built images and supply chain

Deterministic: Image archives are reconstructed without starting containers; supported packaged source, metadata, retained credentials, stored permissions and package inventories are inspected.

Optional analyst: A model can interpret supplied image/source evidence, flag missing deployment context and propose verification work.

Can miss or misclassify: Compiled logic, live deployment overrides, signature trust and dependency CVEs are not assessed. Package inventory and archive consistency do not establish safety or publisher identity.

Validate elsewhere: Use vulnerability/advisory analysis, provenance/signature verification and deployment testing alongside the static image assessment.



Operations and control effectiveness

Deterministic: The catalog retains governance, monitoring, recovery, approval and isolation checks even where no deterministic rule maps to them.

Optional analyst: Full review queues every active acceptance check and can identify evidence gaps or propose runtime/human validation; it can cite exact submitted source text.

Can miss or misclassify: A valid citation proves that a quote exists, not that the model's interpretation is correct. Policies, external services, incident procedures and production outcomes may be unavailable.

Validate elsewhere: Record owner-reviewed evidence, operational exercises and runtime results. A written justification remains an accepted exception, never an automatically validated pass.

Optional request payload optimization

Request	Requested / actual engine	Outcome	Evidence payload bytes
Finding request	headroom / headroom	optimized	3558 -> 3430 128 bytes saved

These are measured evidence-JSON bytes, excluding instructions, response schemas and provider wrappers. Token and cost savings were not measured. Evidence-preserving formatting does not validate the model's interpretation.



Optional-review audit details

Recorded field	Recorded value
Analyst / Enabled	No
Judge / Cli / Arguments	-a, never, exec, --ignore-user-config, --ignore-rules, --ephemeral, --skip-git-repo-check, --sandbox, read-only, --json, --color, never, --disable, shell_tool, --disable, unified_exec, --disable, code_mode, --disable, code_mode_host, --disable, computer_use, --disable, browser_use, --disable, browser_use_external, --disable, browser_use_full_cdp_access, --disable, in_app_browser, --disable, image_generation, --disable, view_image, --disable, artifact, --disable, apps, --disable, plugins, --disable, plugin_sharing, --disable, hooks, --disable, multi_agent, --disable, multi_agent_v2, --disable, skill_search, --disable, workspace_dependencies, --disable, shell_snapshot, --disable, memories, --disable, sleep_tool, --disable, goals, --disable, remote_plugin, --disable, tool_suggest, -c, web_search="disabled", -c, mcp_servers={}, -c, project_doc_max_bytes=0, -c, skills.include_instructions=false, -c, model_reasoning_effort="high", --output-schema, <private temporary directory>/response-schema.json, --model, gpt-6-astra, -
Judge / Cli / Auth mode	cli_managed
Judge / Cli / Cli version	0.154.0
Judge / Cli / Descendant termination	process_group
Judge / Cli / Executable	codex
Judge / Cli / Isolation	CLI capability restrictions; installed executable and administrator policy remain trusted
Judge / Cli / Provider	codex_cli
Judge / Cli / Repository working directory	No
Judge / Cli / Request bytes	5644
Judge / Cli / Request sha256	9bb026f5c15bd9dd66f2dcb09800f62d41e41eb967c43787de8cb813b75793a4
Judge / Cli / Requested model	gpt-6-astra
Judge / Cli / Response bytes	7817
Judge / Cli / Response sha256	73c095f40280411f8fbacbf30a5de880d0bb9919d6d9cfb53d2a853c5b746be7
Judge / Cli / Stage	findings
Judge / Cli / Startup warnings	codex_code_mode_intentionally_disabled
Judge / Cli / Structured output requested	Yes
Judge / Cli / Token budget enforced	No
Judge / Cli / Token optimization / Bytes saved	128
Judge / Cli / Token optimization / Engine	headroom
Judge / Cli / Token optimization / Evidence preserved	Yes



Recorded field	Recorded value
Judge / Cli / Token optimization / Fallback reason	Not configured
Judge / Cli / Token optimization / Headroom version	0.37.0
Judge / Cli / Token optimization / Original payload sha256	1ad9a18de38edb0901b45af07916fb08f1ef5b875d01e4ad53878dee81183257
Judge / Cli / Token optimization / Payload bytes after	3430
Judge / Cli / Token optimization / Payload bytes before	3558
Judge / Cli / Token optimization / Requested	headroom
Judge / Cli / Token optimization / Schema version	1.0
Judge / Cli / Token optimization / Scope	Evidence JSON only; excludes instructions, response schemas and provider wrappers
Judge / Cli / Token optimization / Sent payload sha256	6092d4e472abfc9ba6f6d2567219066dcdd97d1a0c67d9a420be70d440bab691
Judge / Cli / Token optimization / Status	optimized
Judge / Cli / Token optimization / Token savings measured	No
Judge / Cli / Tools policy	disabled_for_advisory_review
Judge / Cli / Transport	official_cli
Judge / Enabled	Yes
Judge / Model	gpt-6-astra
Judge / Omitted open findings	9
Judge / Provider	codex_cli
Judge / Selected findings	2
Judge / Source context requested	Yes
Judge / Source context sent count	2
Judge / Source context skipped	None
Judge / Status	completed



Appendix / Deterministic rule inventory

AI001 / Dynamic Python code execution

eval or exec receives a nonliteral expression. If agent, user, or tool content can reach it, it can execute arbitrary Python. Static analysis does not establish the full data flow.

AI002 / Dynamic command executed through a shell

A subprocess call enables a shell, invokes a shell-specific API, or passes a dynamic command to an explicit shell executable. Shell metacharacters in agent or external input may become executable syntax.

AI003 / Dynamic os shell command

os.system or os.popen executes a dynamically constructed command through the shell. Review the command's trust boundary.

AI004 / Unsafe YAML object construction

YAML is loaded through an unsafe loader or without an explicitly safe loader. Older or unsafe loaders can construct Python objects from input.

AI005 / Executable deserialization requires trusted inputs

Pickle-compatible deserialization can execute code. This finding identifies a dangerous trust boundary, not proof that the serialized input is attacker controlled.

AI006 / TLS certificate verification disabled

Certificate verification is explicitly disabled. A network intermediary may impersonate the remote service and capture prompts, credentials, or tool results.

AI007 / Wildcard cross-origin access

Cross-origin access explicitly permits every origin. For credential-bearing or local MCP services this can expose a browser-accessible trust boundary; reachability and framework behavior require review.

AI008 / Service binds to all network interfaces

A server explicitly binds to a wildcard address. This is a deployment review signal: source alone cannot establish actual network reachability or authentication.

AI009 / Application debug mode enabled

Debug mode is explicitly enabled in server code or configuration. Depending on the framework and deployment, error details or a debugger may become externally accessible.

AI010 / Credential-like literal in source or configuration

A credential-named field contains a nonplaceholder literal. It may be a real secret or test data; validate it without disclosing the value.

AI011 / Private key material in repository

A private-key PEM header is followed by plausible encoded key material. Test keys may be intentional; this pattern does not prove cryptographic validity or production use.

AI012 / Dynamic JavaScript shell execution

A Node child-process shell execution API receives a dynamic command. Agent or external content reaching this value may inject shell syntax.

AI013 / Dynamic JavaScript code execution

eval or the Function constructor evaluates a dynamic value as JavaScript. Review whether user, agent, or tool data can cross this execution boundary.

AI014 / Externally influenced outbound request

An outbound request uses an obvious external-input expression. This is a review signal for SSRF; this local analysis cannot prove whether upstream URL validation exists.

AI015 / Externally influenced filesystem path

A filesystem operation consumes an obvious external-input expression. Review whether canonical path checks and symlink handling confine access to the intended workspace.

AI016 / Race-prone temporary filename creation

tempfile.mktemp returns an unused name without atomically creating the file, allowing a race with another local process.



AI017 / JWT verification explicitly bypassed

JWT decoding explicitly disables signature verification or selects the none algorithm. Unverified claims must never authorize agent or MCP operations.

AI018 / MCP package runner resolves an unpinned artifact

An MCP launch configuration uses npx, uvx, or a similar ephemeral package runner without an exact package version. The executable artifact can change between launches.

AI019 / Remote download piped directly to a shell

Downloaded content is directly piped to a shell. A changed or compromised remote artifact becomes executable without a visible integrity check.

AI020 / GitHub Action reference is not pinned to a commit

A remote GitHub Action is referenced using a mutable tag, branch, or noncommit reference. Its code can change without a workflow diff.

AI021 / Container explicitly runs as root

The default final Dockerfile stage explicitly selects or inherits a literal root user. Build-target selection, external image defaults, variable expansion and runtime overrides require separate validation.

AI022 / Privileged container or privilege escalation enabled

Container configuration explicitly enables privileged execution or privilege escalation, weakening isolation for tool or agent code.

AI023 / Container runtime socket exposed

A container runtime socket is present in configuration. A writable Docker or containerd socket can give a tool control over host workloads.

AI024 / Container image is not digest pinned

A container base or deployment image uses a mutable reference rather than a content digest. The bytes can change between builds or deployments.

AI025 / Direct dependency is not exactly pinned

A direct dependency declaration allows version movement. A lockfile elsewhere may constrain the actual installation; review the effective build process.

AI026 / Authentication explicitly disabled

An MCP or server configuration explicitly disables an authentication-related control. Local stdio servers may rely on an operating-system boundary; assess the actual transport and exposure.

AI027 / Wildcard tool or permission authorization

An authorization or tool allowlist explicitly grants a wildcard or all-tools capability. This may give an agent broader authority than its task requires.

AI028 / MCP token passthrough enabled

Configuration explicitly enables token passthrough or token forwarding. Forwarding an inbound token to an unrelated downstream audience can bypass consent and authorization boundaries.

AI029 / Remote MCP URL uses plaintext HTTP

An MCP configuration points to a nonloopback HTTP URL. Credentials, tool requests, and results may be exposed in transit; network-layer protection is not established by this scan.

AI030 / Browser-side API credential access explicitly enabled

An SDK explicitly enables browser execution despite credential-exposure safeguards. Verify that a durable privileged API key cannot reach client-side code.

AI031 / Agent approval or sandbox safeguard explicitly bypassed

An agent configuration or command explicitly disables approvals or enables unrestricted execution. The impact depends on the process identity, tools, and sandbox.

AI032 / External data inserted into privileged LLM instructions

A system or developer message contains an obvious external-input expression. Untrusted data may be interpreted as privileged instructions; local analysis cannot establish exploitability.

AI033 / Potential secret included in logging call

A logging call directly references a credential-named variable or field. Log processors and retention can broaden access to secrets.

AI034 / Credential-like value embedded in URL query

A URL contains a credential-like query parameter with a nonplaceholder value. URLs can be retained in logs, histories, proxies, and telemetry.



AI035 / Unsafe model checkpoint deserialization

torch.load explicitly sets weights_only=False or a framework disables safe model loading. An untrusted artifact may contain executable object deserialization.

AI036 / SQL query constructed with interpolation

A database execution call receives an interpolated or concatenated SQL expression. If untrusted content contributes, it may change the query's meaning.

AI037 / Archive extraction without an explicit safe filter

A tar extraction call has no explicit safe data filter, or selects a fully trusted filter. Behavior depends on the Python version and archive provenance.

AI038 / Cryptographically weak randomness used for a security value

A credential-, nonce-, or token-named assignment uses a general-purpose random generator. Predictability matters if the value protects access or replay prevention.

AI039 / Server-Side Template rendered from a dynamic template

A server-side template string is dynamically supplied. If agent or user content controls template source, template expressions may execute with server privileges.

AI040 / Unsafe HTML rendering boundary

Dynamic content is passed to an HTML rendering bypass. Agent or tool-generated content may contain executable browser markup if not sanitized.

AI041 / MCP inspector authorization explicitly disabled

The MCP inspector's authorization safeguard is explicitly disabled. A reachable inspector may provide access to connected tools and their privileges.

AI042 / Container uses host namespaces

Container configuration explicitly uses the host PID namespace or host networking. This weakens separation between agent tooling and the host.



Interactive review workspace

Every bound item below remains tied to its original evidence. Blank means unreviewed. Any nonblank decision requires a reason; justified/disabled also require a reviewer. Coverage gaps cannot be justified or disabled. Runtime/human decisions identify outstanding validation and are not passes.

Long fields scroll in compatible PDF viewers. Save with regenerated appearances. If your editor flattens the form or cannot preserve it, use the JSON review workspace instead.

Finding review

[Back to evidence](#)

AI002 Dynamic command executed through a shell - agent.py:9

Evidence binding: ad323b53f43885ee298748c1c0dca72a8775a896d27339f85938dde712c9033b

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Finding review

[Back to evidence](#)

AI003 Dynamic os shell command - agent.py:10

Evidence binding: 7b31e7426d77846d34fa7ea50bfbb1812199f7b46b77f66dfbce6916d84b1c0b

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE



Finding review

[Back to evidence](#)

AI006 TLS certificate verification disabled - agent.py:11

Evidence binding: 43e4fb0bc303f559503786c0d031d75caf50e783334bf8f7e506ebcace6562b0

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Finding review

[Back to evidence](#)

AI005 Executable deserialization requires trusted inputs - agent.py:12

Evidence binding: a6fad86a94e19280ea1f4e0f5a5ec93d0f1d4e8721e6867fcb5deb6812f2278

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE



Finding review

[Back to evidence](#)

AI001 Dynamic Python code execution - agent.py:16

Evidence binding: 6cfe08cd084a25f525beb10bae3b13c4f19c08c83b2c4e8272179d8e126e40ce

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Finding review

[Back to evidence](#)

AI010 Credential-like literal in source or configuration - mcp.json:6

Evidence binding: 65cc927d0508512609f62156a7445a5a831c0404b3604e29055218e5051a770f

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE



Finding review

[Back to evidence](#)

AI031 Agent approval or sandbox safeguard explicitly bypassed - mcp.json:7

Evidence binding: 29f7b1c20cd10e5c51251056a936ea507968141601cbe924c7b3b24eb49ea82b

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Finding review

[Back to evidence](#)

AI029 Remote MCP URL uses plaintext HTTP - mcp.json:10

Evidence binding: 63eb3bc958513eda7ab13ff8bba677c0dc060b5b69338567b34f0de21c8cdf9c

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE



Finding review

[Back to evidence](#)

AI021 Container explicitly runs as root - Dockerfile:2

Evidence binding: 39b14c45874e0192767a9355a9851d3cc06428b3fac7a7dd8171dda0f5374570

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Finding review

[Back to evidence](#)

AI018 MCP package runner resolves an unpinned artifact - mcp.json:4

Evidence binding: 689a1ce34a336fa017539d5c165bf90b946e101d2944ed9e363b7cee9efa1859

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

**Finding review**[Back to evidence](#)

AI024 Container image is not digest pinned - Dockerfile:1

Evidence binding: d59094d946b365f7f2cf4a2de8a505faa7b81ecbb9c95bb6d16596ce64982c2a

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

GOV-01:1 Record owner, deployment, model/version, MCP transport/version, exposed tools, data classes, and external endpoints.

Evidence binding: d17d3bf5d5e65464ce450440469a34be8feb001e378d760bacb5afadfbe336f4

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**Acceptance check review**[Back to evidence](#)

GOV-01:2 Reconcile approved inventory with deployed configurations; investigate unregistered agents and servers.

Evidence binding: 8788f9edc5cda4fdc4381c296bf450da420c6ebc67d031426cc36045bb15fabbb

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

GOV-02:1 Diagram user, model, memory, tool, server, gateway, and downstream service boundaries with their credentials.

Evidence binding: a793286f30809f96a61251636c2851492989087543faab505e32e1152b23b8f5

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**Acceptance check review**[Back to evidence](#)

GOV-02:2 Identify who controls each input and the highest-impact action reachable if that input is malicious.

Evidence binding: 2b3e240099b65535ff170539b4462365f2abd016beca9340652d74cb8c951817

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

GOV-03:1 Assign an owner to each autonomous action and document permitted purposes, forbidden outcomes, and escalation routes.

Evidence binding: 640f656e29c66a1dc7b90e0d5f4753ff2c1da78780df44d14876d9aede40ecbd

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**



Acceptance check review

[Back to evidence](#)

GOV-03:2 Record impact, reversibility, approval requirements, and accepted residual risk before production use.

Evidence binding: 61e3a4c300e167272ce7a3db92a7d019ce0203d566ed010f9fa653c0bfd4dda2

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

GOV-04:1 Give each control an owner, evidence link, validation date, result, and next review date.

Evidence binding: c399f44fd8e6586be3300f66f2cfec24817ea8a95e958eb20ba17b06bb2d2ed6

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

**Acceptance check review**[Back to evidence](#)

GOV-04:2 Time-limit exceptions and require a compensating control; distinguish untested behavior from demonstrated failure.

Evidence binding: 4fa252aebf25bc2fe97a81a92fc40541286a9c48b2210ed48c0c1dd16c72534a

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

GOV-05:1 Review security impact when adding a model, tool, server, data source, skill, or broader permission.

Evidence binding: a2eebc08b3796ef1aeaf20c887f4de356912bc033dca32f7ca62af8c3b0e3be7

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**Acceptance check review**[Back to evidence](#)

GOV-05:2 Require deployment evidence for the complete configured system; a model-only score is insufficient.

Evidence binding: 71e55658a25132ddc613768311985e5b03c51bb2fbd3e7680f59c5994a9b57c6

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

GOV-06:1 For each model, gateway, orchestrator, MCP service, and cloud provider, document which party implements each applicable safeguard and which customer configuration it depends on.

Evidence binding: e5a48bdbd45cc6043e42c7202f51fe7a201f636a23b4a76f280d2de9bd6d7d42

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**Acceptance check review**[Back to evidence](#)

GOV-06:2 Obtain current supplier evidence for inherited safeguards, identify unowned gaps, and record reassessment triggers in the service review.

Evidence binding: 747df9207d276d14b6ac05aebf869a3dd744aee601b6d78950a726f30df9508f

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

AUTH-01:1 Trace authentication to every protected HTTP entry point, including tool calls, subscriptions, and retries.

Evidence binding: dd394938243bb592947b7056854151748dc3d4c3094086f61ee3a273cc1346be

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**



Acceptance check review

[Back to evidence](#)

AUTH-01:2 Verify missing, expired, revoked, or malformed credentials cannot invoke a protected operation.

Evidence binding: 6f7110a0a687f8a6b2d83f92d38d86a081801de55c59d2621bc121adbbdb2bff0

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

AUTH-02:1 Check user/agent identity, tenant, tool, target object, and requested operation immediately before execution.

Evidence binding: bee6ac6d208787e971e66588383dff9bd4539d915ace92715d6c7f7abd6953d0

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

**Acceptance check review**[Back to evidence](#)

AUTH-02:2 Deny by default; test read-only callers against write tools and object identifiers owned by another user.

Evidence binding: 50ae3169049ec47d0cad16ac76bae706ad8b2e45aee2c2f615a288d36c0c8854

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

AUTH-03:1 Verify signature with trusted keys, allowed algorithms, expected issuer/audience, expiry, and required scopes.

Evidence binding: 027b8a1f23b0f27366f3e679a77c895f364167d38314cb981598d7406b03d3e4

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**



Acceptance check review

[Back to evidence](#)

AUTH-03:2 Reject unsigned tokens and tokens minted for another service; decoding a JWT alone is not validation.

Evidence binding: 98636b7e58176c9363228be718a92836813d216049589c1ef434781c325a3749

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

AUTH-04:1 Use audience-bound MCP credentials and separately authorized downstream credentials; never forward arbitrary caller tokens.

Evidence binding: 5cfdcf9753fb80426ce1291fb70329a5209110492bd915be351c076cdb940fd9

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE



Acceptance check review

[Back to evidence](#)

AUTH-04:2 Ensure a proxy cannot use its broader service identity to perform an action the caller cannot authorize.

Evidence binding: 95c722df4dc1003422acc93fc0687273a91e6e799dffaf56df1d7640644b0009

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

AUTH-05:1 Use short-lived scoped credentials where supported, protect refresh tokens, and validate rotation and revocation.

Evidence binding: fdf49b28bb715742444692108031a224804c31eb3f3c78e3b23a6d7a88f5e925

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

**Acceptance check review**[Back to evidence](#)

AUTH-05:2 Avoid tokens in query strings, model context, source, child-process arguments, and diagnostic output.

Evidence binding: c5487fcbcb78d2b73f38f27d2d54907b14d87f41f6a262fde9ce2e8e2f242b6e

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

AUTH-06:1 Test PKCE support and S256, exact registered redirects, transaction binding, and authorization-response issuer validation.

Evidence binding: fa0240e4e32a115d1a63e5482b298b96d39827bf6d336e44398f7c40a322208b

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**Acceptance check review**[Back to evidence](#)

AUTH-06:2 Reject replayed codes, mismatched issuers, unsafe redirect schemes, and unsolicited callback transactions.

Evidence binding: 184da87c488a085b88379b9b8db40ad528cda228225a16d6af2acabcbaa51b26

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

AUTH-07:1 Validate discovered metadata and client metadata URLs before fetching; constrain schemes, destinations, redirects, and response sizes.

Evidence binding: 9f25e4da9e4b1989edfeb6261414703f9004602a1565af592684bda8d3ca627d

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**



Acceptance check review

[Back to evidence](#)

AUTH-07:2 Document trust policy for client registration and prevent discovery from reaching internal metadata or privileged network services.

Evidence binding: c39836603491f3ad1d87069c9c07400da590017d2199b7b653cca4c4a38ceca1

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

AUTH-08:1 Carry authenticated initiator and delegation identity through multi-agent calls instead of trusting identity fields in text.

Evidence binding: 2be937651597c75907a66d86ddaeca2e9090cb2f43fe927e7f6be151ddf5693

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE



Acceptance check review

[Back to evidence](#)

AUTH-08:2 Prevent agents from granting themselves privileges; limit delegation scope, depth, lifetime, and downstream audiences.

Evidence binding: 0fa4c78c23b5c5e342317c68ee99217b912e9d50f501673706caf048269f8055

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

AUTH-09:1 Enroll agents under an accountable sponsor and approved workload identity; verify identity claims before issuing credentials or granting discovery and execution access.

Evidence binding: cd2e0fbecac10fa8ed678296d7cd358c27ec81e911b345168c28a89d89c0590b

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

**Acceptance check review**[Back to evidence](#)

AUTH-09:2 Test retirement, sponsor departure, redeployment, and identity compromise; remove stale credentials, cached grants, registrations, and downstream access.

Evidence binding: fb8fb6d77005a72b888005ada9754afc6a1f6c7ee7d9eebef345f6a81e8614bc

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

MCP-01:1 For HTTP, reject invalid Origin values and verify local deployments bind only to intended interfaces.

Evidence binding: 7a968dbddbe47f88057c347b6bde74650d48ed8c1e0b16278ec04aaf327fef03

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**Acceptance check review**[Back to evidence](#)

MCP-01:2 Use TLS for remote protected endpoints; test DNS rebinding and proxy/header behavior in deployment.

Evidence binding: b216ce951e81bf618e41c850da984b79d3dbd1db2549a8548217a6aede bbd4db

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

MCP-02:1 Apply schemas and semantic bounds before executing every tool; reject unknown properties where appropriate.

Evidence binding: fe1d545408aa2433bb89ad4f1e3631ba41a55617e9b344d8adfe0aca4d6dd18a

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**



Acceptance check review

[Back to evidence](#)

MCP-02:2 Bound sizes and nesting; validate declared structured output and render errors without leaking secrets.

Evidence binding: 7c376ac9305f4b3116e4f1166adfdc69cbca2ca000175202c9bcb2d832528712

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

MCP-03:1 Inspect descriptions, schemas, resources, icons, and results for instructions that cross tool or user boundaries.

Evidence binding: e485b99b6b2bd9e94c270942bf3b5efd6183f613908865fb466338a10250769a

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

**Acceptance check review**[Back to evidence](#)

MCP-03:2 Never let readOnlyHint, destructiveHint, or other server claims replace independent authorization and approval policy.

Evidence binding: 577eab77534da467a8200350f2fa6e67501f6a416b0bdcea057f9d34c0d96bbf

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

MCP-04:1 Bind tool approval to verified server identity and the reviewed tool definition or version.

Evidence binding: 83ec409671cd7d13a8be41ad170c7a048ee6a0e83e19f9d514b2c184f2d69a67

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**Acceptance check review**[Back to evidence](#)

MCP-04:2 Revalidate changes after reconnect/list updates; disambiguate collisions across servers without trusting display names.

Evidence binding: 06baa39aeab29563793aee1c3091d4748df21ce666fbd3ad9529d32966ba7d7c

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

MCP-05:1 Authorize every state handle against its owner and tenant; enforce expiry, unpredictability, and replay boundaries.

Evidence binding: 81e1826a8889199bcd9d4a6493149925a05998d6b61a5f986cc6d9a5d2c8f8f9

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**Acceptance check review**[Back to evidence](#)

MCP-05:2 For older sessionful protocol versions, test session hijacking and cross-user resumption; a session ID is not authentication.

Evidence binding: 637c6cc7deec65e06999f64b988bc542ebcdf55ff854bb18a50639f2473a2b6b

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

MCP-06:1 Apply host policy and user control to sampling requests, context sharing, model selection, and associated tool access.

Evidence binding: 20b1042de5f2e4fc7f3be61390c534562b7640e600ec3c3dceaf2ebdd21a5e8

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**



Acceptance check review

[Back to evidence](#)

MCP-06:2 Test whether an untrusted server can induce disclosure from unrelated conversations or recursively consume model budget.

Evidence binding: f4d9d9e26035c5a9a69d428225dbae417777cf19eff82584f19323a3eda9731f

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

MCP-07:1 Keep sensitive credential collection out of form-mode elicitation; validate and visibly identify URL destinations.

Evidence binding: 9adee9a893c10eb1eb3428d6a55d426e546b72cc0c2b1428f9436f3f43e312bb

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

**Acceptance check review**[Back to evidence](#)

MCP-07:2 Test cancellation, phishing URLs, unsolicited interactions, and replayed completion state against the selected protocol version.

Evidence binding: bc9b9d01be078c48ebc887830e99a5c6c7d04c20d1c8a9b048fca91fab0ba0e3

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

MCP-08:1 Treat declared roots as scoped information, not an operating-system sandbox or complete authorization mechanism.

Evidence binding: 7bf2861b5b65114113de24ceba857189478056fb227065b49c67f2b665782049

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**Acceptance check review**[Back to evidence](#)

MCP-08:2 Enforce allowed paths at file access and test traversal, symlinks, alternate encodings, and writes outside the workspace.

Evidence binding: 2f608c853384425ed3269398b459c8ff875b7320e65234dd8c8c170e342f7257

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

MCP-09:1 Approve executable and package identity before starting a stdio server; use argument arrays and a minimal environment.

Evidence binding: e505e18b74aded3b3b23d843c3117cc8252dd375312e8b37f7f29f5496d468d5

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**Acceptance check review**[Back to evidence](#)

MCP-09:2 Restrict proxy process-spawn APIs and child filesystem/network permissions; separate stdout protocol traffic from logs.

Evidence binding: bcbfab96b8572375f71371a9ae8600c81c8b8c2fd5684ebc220f0eb86bbc44a9

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

MCP-10:1 Record supported revisions and test their capability, metadata, header consistency, stream, and cancellation rules.

Evidence binding: 51870ff24b2149d09c7faef293afa44e589df86299329a9a277fd94a211cf1da

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**Acceptance check review**[Back to evidence](#)

MCP-10:2 Prevent caches and request continuations from crossing authorization contexts; do not apply legacy handshake assumptions universally.

Evidence binding: 721fd73761510f9bf3673d679e59baf482d1b14c636409a152767bff8afaa51d

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

AGT-01:1 Place allow/deny decisions at the execution boundary using trusted policy inputs and constrained tool capabilities.

Evidence binding: ae3e23c88aa438e35dd22ff43b02286cc057f80bf681f64d671c713fc102279

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**Acceptance check review**[Back to evidence](#)

AGT-01:2 Show that an injected instruction cannot disable policy, choose privileged credentials, or bypass approval.

Evidence binding: 3a80da5818c1640be054f32cf0503317ef4444404b217a598f1bda866fa4ed90

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

AGT-02:1 Present actual recipient, target, arguments, data disclosure, and consequences for high-impact approval.

Evidence binding: 506513744b03b738a8a9cd1c9dd2272c7d59f581904ea2cca259c4d2f2e7a1f2

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**Acceptance check review**[Back to evidence](#)

AGT-02:2 Invalidate approval if arguments or target change; test races, delayed retries, and approval reuse.

Evidence binding: f8c317658f83648fe25b42b08b89c675823b90c0359c108f862c907e95e7ec22

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

AGT-03:1 Track origin and trust level for web pages, documents, messages, OCR, tool results, and repository instructions.

Evidence binding: 8c0a1a7ef63f2372ec15fb7788126440d9b72155f696ffae062ae51be403535a

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**Acceptance check review**[Back to evidence](#)

AGT-03:2 Test direct and indirect goal hijacking; formatting delimiters and prompt warnings alone are not access controls.

Evidence binding: f0c07e018277a9a065635e8bf184fe16377cbd78df311c12491b7562d2040dfc

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

AGT-04:1 Enforce document and memory ACLs at retrieval and update time, including vector search metadata filters.

Evidence binding: 56a3c2a139e1cb833df692fd7792b35ec628fb83bda6c84931590f827a1c1be5

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**Acceptance check review**[Back to evidence](#)

AGT-04:2 Test poisoned memory persistence, cross-tenant retrieval, provenance loss, deletion, and stale privileged context.

Evidence binding: a6e73347f399ac10c258b743ace16fccf97e06e3597ad84f911b6d411c57a7aa

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

AGT-05:1 Constrain delegated tasks and verify messages against authenticated senders, expected schemas, and allowed transitions.

Evidence binding: 593b38597332334723686b039604db41efdaa30c215da288182df38b38897411

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**



Acceptance check review

[Back to evidence](#)

AGT-05:2 Test impersonation, conflicting instructions, cascading failure, and privilege growth across handoffs.

Evidence binding: e0567b94ae88b616ef6731b4d60f0f5aaa7088608ad9d729543465157a18af4c

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

AGT-06:1 Inventory skill files, prompts, hooks, memory seed files, MCP configuration, and other executable workflow inputs.

Evidence binding: 2deef867951af652da87e9d8d1897258bd4727d10d7123cb570d38edbc4f2c14

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE



Acceptance check review

[Back to evidence](#)

AGT-06:2 Require review for changes that add commands, access, or persistence; external repository text cannot become trusted policy.

Evidence binding: 6be922e74d0f8db0681402037eaa65a425678871694e57c2fef1f21834e882b

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

AGT-07:1 Apply destination and data policies to URLs, searches, tickets, messages, uploads, and telemetry generated by agents.

Evidence binding: 3754d4af9537af5cc6a5c51c198016f5140e715c31e88e18f4415335898fcee1

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

**Acceptance check review**[Back to evidence](#)

AGT-07:2 Use canary data to test encoded leakage and combinations of otherwise permitted tools.

Evidence binding: afa367a4c58a9e708f3bb724cfd2edcb769e78ea2d07c1763e008c3297f7fbf3

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

EXEC-01:1 Find shell execution and constructed command strings; use fixed executables, argument arrays, and allowed argument values.

Evidence binding: b3e02275f808024846e5412d78bdf07e86625d7a6032166ef56639cdb9495f4a

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**



Acceptance check review

[Back to evidence](#)

EXEC-01:2 Test untrusted tool inputs containing shell syntax, option injection, command substitution, and hostile filenames.

Evidence binding: b84f2a1d9df60d7abadffc5d645a989020cc37d4198a2d19afed5eed29f9a73

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

EXEC-02:1 Locate eval, exec, dynamic imports, templates, notebooks, and interpreter tools accepting model or user content.

Evidence binding: f6ba6239a9012ebb95711b6a4192bc6e244ae7393a1846fbac6faebed2784c36

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE



Acceptance check review

[Back to evidence](#)

EXEC-02:2 Run required code execution in a disposable restricted environment with explicit filesystem, network, CPU, and time limits.

Evidence binding: 0edc068d6802f9eeac09cb5165f7079534c366f123f9b3c5f4576ed60975fd1

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

EXEC-03:1 Use bound query parameters and allowed query shapes; inspect SQL, NoSQL, graph, and search-language construction.

Evidence binding: e3fb24ab5628a9a6fcaef68bb32cd839199de5747e77dde2a60cf73eebe3e9d4

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE



Acceptance check review

[Back to evidence](#)

EXEC-03:2 Separate read/write database identities and test whether generated queries can escape permitted objects or operations.

Evidence binding: 47b83832d8063049296af5fd2554c9007176b15da1a094b381333117d9fdb47a

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

EXEC-04:1 Resolve and enforce allowed paths at access time; constrain uploads, downloads, extraction, temporary files, and permissions.

Evidence binding: 1a8ee0a45400f1a6ddc59202b71080e409e97d5b45db390c6a2cce37d4528b80

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

**Acceptance check review**[Back to evidence](#)

EXEC-04:2 Test symlink races, archive traversal, absolute paths, overwrite attempts, and secret-directory reads.

Evidence binding: c09e0759b46ca80cbd8871d80b0aa2f4357b9e5317c088bfb213807fbc3da317

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

EXEC-05:1 Restrict destinations and schemes at connection time; revalidate DNS resolution and each redirect.

Evidence binding: fbb54ff114866869054bdfea1dd9f0751f6fe3d16e140adb24646f8a32064664

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**



Acceptance check review

[Back to evidence](#)

EXEC-05:2 Test loopback, private/link-local IPv4 and IPv6, cloud metadata, alternate encodings, and redirect-to-private cases.

Evidence binding: 9d96bb1b18796bfb17e6191a0265fcee430b7e2570b00392cd57501183f00ec0

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

EXEC-06:1 Inspect pickle, unsafe YAML, object deserialization, XML entity expansion, and unconstrained recursive parsers.

Evidence binding: ec8a610135f933bc44861d4d37456a52f38212741b731babfd9ea67d5b761d47

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE



Acceptance check review

[Back to evidence](#)

EXEC-06:2 Use data-only formats with byte, nesting, and type limits; test malformed input and expansion attacks.

Evidence binding: 0629d7e9d855759d45c25c27c51742f34cfd025169f693f2460a0d0f21d94239

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

EXEC-07:1 Use context-specific escaping for HTML/Markdown, avoid unsafe DOM sinks, and validate links and embedded media.

Evidence binding: 497d070e92b46568b0649b44024ed80a14576fcff01e5c0f819ecd33a3a613c0

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

**Acceptance check review**[Back to evidence](#)

EXEC-07:2 Test active SVG/HTML, malicious URLs, terminal escapes, and spreadsheet formulas in exported reports.

Evidence binding: 1f0f8c4e2b66916a9776e96fc37ee284c99e70a9adca78c6a947e364215f63ca

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

DATA-01:1 Inspect code, examples, configuration, notebooks, test fixtures, and generated artifacts for secret-like values.

Evidence binding: a17298608828636ce35b9cfe50f6a8977ed30b8bf91b4f7360e223a59f366e7e

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**



Acceptance check review

[Back to evidence](#)

DATA-01:2 Verify actual exposures with the owner, rotate real credentials, and remove them from reachable history and artifacts.

Evidence binding: bb470525fe4e9e7b574c36e9fdd49c0a8280addc3e4ff41a06964ae0c70de980

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

DATA-02:1 Map which prompts, tool outputs, memory, and code leave the environment and identify the receiving provider/gateway.

Evidence binding: 45917920e8022ae22caa64c63b07819dc3037290e41601b2b187162bb92a33ba

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE



Acceptance check review

[Back to evidence](#)

DATA-02:2 Document allowed data classes, processing location, retention, and training use; redact before transmission where required.

Evidence binding: b258baf3fed4a129ba02295cf0ff41f344dc74a06d8d69445006370f443e55bd

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

DATA-03:1 Redact secrets and sensitive payloads before logs, traces, exception strings, and dashboards persist them.

Evidence binding: 8aeb7d5fcd7aae802edbdab6be3f315f1163021a3300f1837ebabc62c9ac7169

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

**Acceptance check review**[Back to evidence](#)

DATA-03:2 Test the failure paths and provider errors as well as success paths; restrict access and export destinations.

Evidence binding: c59fc4dd29b78028f5f3d99ea3c2798e2683b4609434b3ddf2c9187d7d374f10

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

DATA-04:1 Record source, owner, version, transformation history, and integrity evidence for datasets, retrieval corpora, and memory seeds.

Evidence binding: e8810731657051177b81687fe263b62eeaf108e572a4d68d5c9cdcbd1da675f6

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**Acceptance check review**[Back to evidence](#)

DATA-04:2 Quarantine unexpected changes and test how poisoned or stale data is detected, removed, and replaced.

Evidence binding: 831a5d7ca75c02e4a1809b94ebd1f8a8c806396b665a7613e946ccfd64025e1f

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

DATA-05:1 Apply expiry and deletion to prompts, embeddings, caches, memory, tool artifacts, backups, and provider-held data.

Evidence binding: 1ba64de342585b7e79fe82ce9909d9c94a79a49b1802fab1e3eee6caa3189503

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**



Acceptance check review

[Back to evidence](#)

DATA-05:2 Verify deleting a source record removes or invalidates dependent retrieval content and access grants.

Evidence binding: ba1603bb548cdcc0e3ec02f973f8c049cab01cc007a170de05445373710a4e39

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

DATA-06:1 Check transport verification, storage access controls, encryption settings, key separation, and backup permissions.

Evidence binding: d2bac2d1b0994acb9203f489d557eb71cee36c2f95d3c67e298725d5f2c528d7

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE



Acceptance check review

[Back to evidence](#)

DATA-06:2 Validate key rotation and denied access using a principal outside the authorized tenant or operational role.

Evidence binding: 48c065b94d61b3c2fc361dacccb0eccd1aa50d09f8a3ac0aca0ca35f7fe900fd

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

SUP-01:1 Review lockfiles and exact versions or immutable digests for packages, images, MCP servers, models, and plugins.

Evidence binding: d6f326b5b7d2f0fd18be13a0826f57394f46ac5e15756fb4d117415c11371872

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

**Acceptance check review**[Back to evidence](#)

SUP-01:2 Flag runtime installs, floating tags, remote scripts, and dependency sources outside approved registries.

Evidence binding: 478e64d0b395bcfd06ac50d1a6b61c96364548e9aa8474e594f3059b7e4d347f

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

SUP-02:1 Run appropriate package/container advisory tools against resolved dependencies and save database date and tool version.

Evidence binding: 942788e5d0a9d8be35f0e9df4ec6d08e58a264533a8623a47185d1844e24f562

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**Acceptance check review**[Back to evidence](#)

SUP-02:2 Triage reachability, fix availability, support status, and transitive dependencies; source pattern scans do not establish CVE coverage.

Evidence binding: 98384bac5b1d0b0a2f7e4e41cb94595e8769bc80b039f32ae24bee862f14a08a

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

SUP-03:1 Verify publisher identity, hashes/signatures, build provenance, and intended origin before enabling artifacts.

Evidence binding: f8f81e545c74c92d4159c63ffd39e48df02a2b9b4ea4e7ec30d8b01376a83c60

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**Acceptance check review**[Back to evidence](#)

SUP-03:2 Review model loading and serialization behavior; an integrity hash cannot make an untrusted publisher safe.

Evidence binding: 69d05589800207120e3c2e0ffd4c9d4a82baf93dfdd908a40fa5909482e8e237

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

SUP-04:1 Restrict CI credentials and workflow permissions; review actions, build scripts, and release provenance.

Evidence binding: 146c0d137766403739a06310f0fb84e7ff8b6b0ed1fe5135963cf5dc24f7379c

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**Acceptance check review**[Back to evidence](#)

SUP-04:2 Prevent untrusted contributions from executing with deployment secrets or changing approved agent policies.

Evidence binding: 43a9d43739c68a0d61943767c5bcbb403ace9b18b1992cb34a9987ddc3ad413f

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

SUP-05:1 Review root/privileged containers, host mounts, Docker sockets, unrestricted egress, debug mode, and public management endpoints.

Evidence binding: 1eff4f34e8d100989763c7fe2fcc1915bc4017be3df9e95fc43b97d7c531622d

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**



Acceptance check review

[Back to evidence](#)

SUP-05:2 Separate agent execution from control-plane credentials and audit storage; test isolation in the deployed environment.

Evidence binding: 3f097778b443f0d9a80ed034492f472e7a276ca8c3cce69c821dc5de7a1672ab

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

SUP-06:1 When training or fine-tuning, isolate development, evaluation, and production identities, data access, registries, and release permissions.

Evidence binding: e99d5dc82974607dcdc8ce33a063a94680f3a95cecc144e8abb0cad90cda04f1

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

**Acceptance check review**[Back to evidence](#)

SUP-06:2 Protect datasets, weights, adapters, and configuration separately; monitor modifications and demonstrate that an untrusted training job cannot replace an approved production artifact.

Evidence binding: 85c95bd8ef53d516d92ea55bd8044e7d365531838aad4385db087c1fd8412fa1

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

OPS-01:1 Record initiating identity, delegated identity, tool/server/version, approved arguments, decision, outcome, and correlation identifiers.

Evidence binding: 46ee52511946054027e8cc96f5f5661630908437a8b82da8517f9fce79edc7e6

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**



Acceptance check review

[Back to evidence](#)

OPS-01:2 Protect log integrity and clock consistency; ensure agents cannot erase their own action history.

Evidence binding: 43885cb737dd368eeb607fc15ba15ab498fb745a81627c68fe771375ae0aa8d3

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

OPS-02:1 Set server-enforced limits for iterations, tokens, tool calls, recursion, parallelism, bytes, cost, and elapsed time.

Evidence binding: af779331be978db541317dc384124a8252137af339ec59c6b64fa69c85176502

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE



Acceptance check review

[Back to evidence](#)

OPS-02:2 Exercise stuck loops and amplification paths; verify limits apply across retries and child agents.

Evidence binding: 9a4813608a9ff998d310a91f44ec7a2fc2cbf9e564452e7cb33758d275a6ca4d

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

OPS-03:1 Provide a tested stop mechanism that revokes work, credentials, queued actions, and child tasks.

Evidence binding: 0173335269b99e8b6ef202e915e213e0410116ba73afab0cc3976d0c70a4d937

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

**Acceptance check review**[Back to evidence](#)

OPS-03:2 Measure stop latency and verify cancelled or disconnected requests cannot later commit prohibited side effects.

Evidence binding: cb22bd284b9dde9452e9d9e0e78dbbc49f730e69a6bea27192931aa99fbe3131

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

OPS-04:1 Deny or escalate when policy, identity, or approval checks fail; prevent fallback paths from widening privilege.

Evidence binding: 97694a8c58a3678e88324025e24b131ac7511d058eb4efb17f4524f2bfa4dc9c

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**Acceptance check review**[Back to evidence](#)

OPS-04:2 Test outages, partial failures, timeouts, retries, idempotency, and recovery of transactions with external effects.

Evidence binding: 89fd8caefe218d5f770fd6a34746353901abb505d4d6de6d60c2dcd8ad5caae8

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

OPS-05:1 Alert on unusual tool use, new destinations, scope growth, repeated denials, cost spikes, and unexpected state changes.

Evidence binding: 3a32b1fa923fa3577d5977b79754b8c2859374e0fc1d98fdee25e54453f0d6fc

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**

**Acceptance check review**[Back to evidence](#)

OPS-05:2 Validate alerts with seeded events and test rollback of models, prompts, tools, policies, and poisoned memory.

Evidence binding: b6faa15647282b3b52520db993510792ee2829572bd136d53eb3c4a47dd61923

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

OPS-06:1 Maintain procedures to isolate agents, revoke credentials, preserve evidence, notify owners, and recover trusted state.

Evidence binding: 697a557c42236ff2eb2dee66b8dd7b2e54c2e33e1db2dcf706c5a71a01036e13

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**



Acceptance check review

[Back to evidence](#)

OPS-06:2 Exercise an AI-specific incident and define approved vulnerability/intelligence-sharing channels without exposing sensitive evidence.

Evidence binding: fc8e05eb2ba11573ee8217e74475cafbe02bfb33d022462035bca46c1fd1002a

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

TEST-01:1 Run paired benign and adversarial workflows with representative tools and attacker-controlled external content.

Evidence binding: 263ae976ae9a721fba40e5c03ec673a5d8faca0f46fc5e0052dbb3b0bab857a3

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE



Acceptance check review

[Back to evidence](#)

TEST-01:2 Record attacker success, authorized task success, blocked benign actions, and the observed unauthorized side effect.

Evidence binding: 997e0c9c4f79669c00ddb510f026c064ce6883fc82f28f50ca945a53b1cee441

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

TEST-02:1 Vary payload wording, placement, modality, attacker knowledge, and attempts; rerun after changing defenses.

Evidence binding: 4f290230aa9151a4f5386c6d5a4cbbf47a1a33b3c6622cb51fadc62ae7554040

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE



Acceptance check review

[Back to evidence](#)

TEST-02:2 Report per-scenario outcomes, sample counts, attack budget, uncertainty, and model/harness versions instead of only an average.

Evidence binding: e9f97842c8d9f2e6c1352e4403fba368fd769df2ed153f279ac7cdbcb1901738

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

TEST-03:1 In an isolated test environment, exercise invalid tokens, wrong audiences, origin abuse, malicious servers, and protocol fuzzing.

Evidence binding: 6dd535fa9cdde2e5bb92356d6cb44b57ca5ec54441395f90f8f009efa41972c7

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

**Acceptance check review**[Back to evidence](#)

TEST-03:2 Adapt scenarios to the deployed MCP revision and transports; preserve request/response evidence with secrets removed.

Evidence binding: fde20d30e7d298cd112cd56eb705d9fb5ac8d860bd1ec9f3f36190b2a2d5ffe4

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

TEST-04:1 Create two principals and attempt cross-access to objects, memory, caches, handles, subscriptions, and execution results.

Evidence binding: 4b288a454d6163a7fff9dfbbc6fbd25ef16a7f4ea7c68dd7895e29954d22df77

DECISION

Unreviewed

REVIEWER**REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**



Acceptance check review

[Back to evidence](#)

TEST-04:2 Repeat after reconnect, delegation, failed authentication, concurrent requests, and privilege revocation.

Evidence binding: 908e1656e451dbbb85a3a1ba43954a9578fe148b2d1a36ff9a2faa5adb9662c9

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

TEST-05:1 Use explicit forbidden-action canaries to verify enforcement survives hostile content, tool substitution, and delayed execution.

Evidence binding: 7cfc0e07af20be8a7b849d9e13f249a74acf2f70747dcff5b01381918c547bf2

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE



Acceptance check review

[Back to evidence](#)

TEST-05:2 Confirm paths through retries, fallback models, alternate tools, and child agents enforce the same boundary.

Evidence binding: cd7dcad15fe08451d01f21130aa33deb6c00e915a38a27c581d28e0e4642cf23

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

TEST-06:1 Run language-aware SAST, dependency review, secret scanning, and authorized integration tests for exposed services.

Evidence binding: f30dc2cc497cdaf613c63284edd73969113e4bda628fb45a5914da9cbc48a370

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE



Acceptance check review

[Back to evidence](#)

TEST-06:2 Exercise reachable injection, XSS, SSRF, path traversal, deserialization, and access-control risks with safe fixtures.

Evidence binding: b87f952ef7c7a44511e42295a0ad0996305f0d5a4e38fc744f239a64936a9c40

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

TEST-07:1 Simulate oversized messages, slow peers, streaming floods, repeated errors, runaway agents, and unavailable dependencies.

Evidence binding: 64dd93ddd1b2f63e5b51f201a5b3242cc9d9a6dc0e4f47029ad3343381229e3e

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE



Acceptance check review

[Back to evidence](#)

TEST-07:2 Verify quotas, shutdown, telemetry, and alerts work together without leaking payloads or losing attribution.

Evidence binding: 28a598466ebc1f653b1a45c16bc6113035be7a9ad062f0a1a2de88597ee34e31

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

TEST-08:1 Treat repository text and model verdicts as untrusted; test prompt injection, fabricated locations, invalid JSON, and timeouts.

Evidence binding: dbde2022a9883c0afbcd18ad4a9b4987b48a1fbc36e1fff2dedf7f9bc61b194

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

**Acceptance check review**[Back to evidence](#)

TEST-08:2 Compare against labeled cases, retain deterministic results, document model variability, and never equate a judge approval with control validation.

Evidence binding: 257e1aabfad7d4a45608dbba985f324dca5ac5fb2a9f6f87e46c01d4c16250a9

DECISION**REVIEWER****REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE****Acceptance check review**[Back to evidence](#)

TEST-09:1 Where applicable, assess suspicious triggers, model extraction, and disclosure of private training examples under an explicit attacker access and query budget.

Evidence binding: c44021ff83413f4c95806c565be68a7b10274a8af06a2b137daf084085604f8e

DECISION**REVIEWER****REASON / JUSTIFICATION****REVIEWED AT (YOUR DATE)****EVIDENCE REFERENCE**



Acceptance check review

[Back to evidence](#)

TEST-09:2 Retest acquired or retrained models and adapters before release; document measured failures, model identity, coverage limits, and accepted residual risk.

Evidence binding: 47ccf984558751144ca862ef181b99d3ec8d62ad20e037723173f2ce60db2168

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE